

THREATS AND ATTACKS ON ENDPOINTS

After completing this module, you should be able to do the following:

- 1 Identify the different types of attacks using malware
- 2 Define application attacks
- 3 Explain how threat actors use application attacks
- 4 Define adversarial artificial intelligence attacks

Front-Page Cybersecurity

Despite the skyrocketing number of ransomware attacks in the past five years, ransomware has been used for more than 30 years. The first known ransomware attack was initiated in 1989 by an AIDS researcher. He carried out his attack by distributing 20,000 floppy disks to other AIDS researchers in more than 90 countries with an accompanying message that the disks contained a program that analyzed an individual's risk of acquiring AIDS. However, the disk also contained ransomware that remained dormant until the computer had been turned on 90 times. At the next startup, the ransomware displayed a message demanding a payment of \$189 (plus \$378 for use of the program).

Today, ransomware attacks are running rampant. There were an estimated 184 million ransomware attacks in 2018. In 2019, attackers using ransomware turned their sights on government agencies, educational institutions, and even health-care providers. But these incidents were not just expensive inconveniences; the disruption they caused put health, safety, and even lives at risk. Ransomware attacks on healthcare providers resulted in emergency patients being redirected to other hospitals, inaccessible medical records, cancelled surgical procedures, postponed lab tests, and suspended hospital admissions. Emergency responder and law enforcement agencies were also common victims so that emergency 911 services were interrupted, police were unable to access details about criminal histories or active warrants, and jail doors could not be opened.¹

What is fueling the rapid rise of ransomware? Is it a growing sophistication of attackers? Misguided users? More powerful ransomware? The answer, according to some, is none of these but something entirely unexpected.

The rapid rise of ransomware is attributed to cyber insurance.

Cyber insurance started 20 years ago by Lloyd's of London, and today it is an \$8 billion industry. About 80 percent of Lloyd's cyber insurance is written for U.S. entities. A cyber insurance policy is not cheap. The city of Houston is now taking out three \$10 million policies from three different insurance companies for a total of \$30 million in coverage. For this, Houston will pay \$471,400 annually in premiums. Another Texas city, Fort Worth, has only a \$5 million policy, but it costs \$99,570 in annual premiums.

How can the blame be placed on cyber insurance agencies for the rapid growth of ransomware?

Following a ransomware attack, enterprises and government agencies need to get back to normal as quickly as possible. Every minute they are locked out of their computers because of ransomware, they are losing money or putting individuals at risk. Cyber insurers claim that it makes more financial sense to pay the ransom and get the key to unlock encrypted files so that organizations can get back to normal quickly.

However, paying the ransom is actually an advantage to the cyber insurance agencies. By paying the ransom, cyber insurance agencies hold down their overall costs. They do not have to pay for lost revenue due to downtime brought on by ransomware or pay for third-party security consultants to aid in the data recovery. But when insurers reward attackers by paying the ransom, they might actually be encouraging more ransomware attacks because attackers know they will be paid. In addition, an increase in the number of ransomware attacks could frighten more businesses and government agencies into buying cyber insurance policies.

But doesn't paying the ransom cost the cyber insurance agencies money? No. Cyber insurance is a very lucrative business. The "loss ratio" is an industry standard for comparing premiums paid for insurance (what comes in) against insurance claims (what goes out). For all property and casualty insurance, like auto insurance and homeowner insurance, that loss ratio is about 62 percent (or for every dollar of premiums, about 62 cents are paid out in claims). However, for cyber insurance, it is only 35 percent, meaning that the cyber insurance agencies pay 35 cents in claims for each dollar of premiums.

Some researchers claim that cyber insurance is increasing number of ransomware attacks. In fact, the chief technology officer for a well-known antivirus company has said, "Cyber insurance is what's keeping ransomware alive today."²

Throughout the years, different words have been used to describe network-connected hardware devices. Thirty years ago, when the TCP/IP protocol was becoming popular, the word *host* referred to any communicating device on the network (networks were made up of hosts). Twenty years ago, as servers became more popular, the word *client* was used (clients made requests to servers).

Today, a different word is commonly used when referring to network-connected hardware devices: *endpoints*. This change reflects the fact that devices that are connected to a network today are far more than a computing device with a keyboard and monitor. Instead, devices ranging from mobile smartphones and tablets to wearable fitness trackers, industrial control system sensors, automotive telematics units, and even personal drones are all network-connected hardware devices. The word endpoint has become an accurate description of today's end-user technology devices.

This change in terminology also reflects the increased risks that have multiplied—exponentially—with the increase of these new devices. Instead of protecting hosts or clients located inside a network security perimeter, today each endpoint is a target for attackers to attempt to steal or manipulate their data. And because the endpoints are connected to the network, a vulnerability on an endpoint can result in an attack that penetrates the network and infects all other endpoints. In short, today *every endpoint is a potential entry point*.

This module examines threats and attacks on endpoints. It begins by looking at attacks using various types of malware and then looks at application attacks. It concludes by examining adversarial artificial intelligence attacks.

ATTACKS USING MALWARE

CERTIFICATION

1.2 Given a scenario, analyze potential indicators to determine the type of attack.

In a legal setting, a "computer contaminant" is defined as any set of computer instructions that is designed to modify, damage, destroy, record, or transmit information within a computer, computer system, or network without the intent or permission of the owner of the information, computer system, or network.³ This legal definition is the basis for the definition of the cybersecurity word **malware** (*malicious software*), which is software that enters a computer system without the user's knowledge or consent and then performs an unwanted and harmful action. Malware is most often used as the general term that refers to a wide variety of damaging software programs.

Malware is continually evolving to avoid detection by improved security measures. According to one report, the number of new malware releases every month exceeds 20 million, and the total malware in existence is approaching 900 million instances.⁴ Yet no standard has been established for the classification of the different types of malware so that like malware can be grouped together for study.

One attempt at classifying the diverse types of malware can be to examine the primary action that the malware performs and then group those together with similar actions. These malware actions used for groupings are imprison, launch, snoop, deceive, and evade.

Imprison

A prison is a building or location housing individuals who have been deprived of their freedom. Some types of malware attempt to take away the freedom of the user to do whatever they want on their computer. The types of malware that imprisons are ransomware and cryptomalware.

Ransomware

One of the fastest-growing types of malware is ransomware. **Ransomware** prevents a user's endpoint device from properly and fully functioning until a fee is paid; that is, it takes away a user's freedom from freely using their computer until the ransom is transacted. The ransomware embeds itself onto the computer in such a way that it cannot be bypassed, and even rebooting causes the ransomware to launch again.

Ransomware became widespread around 2010. This earliest ransomware displays a screen and prevents the user from accessing the computer's resources (called *blocker ransomware*). The screen contains instructions that pretends to be from a reputable third party, giving a "valid" reason for blocking the user's computer. One example is ransomware that purports to come from a law enforcement agency. This message, using official-looking imagery, states that the user performed an illegal action such as downloading pornography and must immediately pay a fine online by entering a credit card number. Figure 3-1 shows a blocker ransomware message.

NOTE 1

The popular vulnerability feed Mitre Common Vulnerabilities and Exposures (CVE) assigns a CVE ID number, brief description, and any pertinent references but does not try to group common vulnerabilities together. Likewise, the National Vulnerability Database (NVD) does not attempt to classify vulnerabilities. Both CVE and NVD are covered in Module 2.

NOTE 2

Some malware has more than one of these actions. However, in terms of classification, the *primary* action of the malware is used here.



Figure 3-1 Blocker ransomware message

Another variation of this type of ransomware pretends to come from a software vendor and displays a fictitious warning that a software license has expired or there is a problem with the computer such as imminent hard drive failure or—in a touch of irony—a malware infection. This ransomware variation tells users that they must immediately

renew their license or purchase additional software online to fix a nonexistent problem. The ransomware example in Figure 3-2 uses color schemes and icons like those found on legitimate software.

NOTE 3

Researchers have developed an entirely new means of detecting a ransomware infection, and it works even if the type of ransomware is new and has never been seen before. When ransomware begins to encrypt files, the computer's temperature, power consumption, and voltage levels experience a surge. Sensors can detect these surges and immediately halt the encryption process, stopping ransomware dead in its tracks.

NOTE 4

Originally, the FBI did not support paying a ransom in any circumstances. It said, "The FBI does not advocate paying a ransom, in part because it does not guarantee an organization will regain access to its data . . . Paying ransoms emboldens criminals to target other organizations and provides an alluring and lucrative enterprise to other criminals." But in late 2019, the FBI seemingly softened its stance by adding, "However, the FBI understands that when businesses are faced with an inability to function, executives will evaluate all options to protect their shareholders, employees, and customers."⁸



Source: Used with permissions from Microsoft

Figure 3-2 Ransomware computer infection

As ransomware became more widespread, the threat agents dropped the pretense that the ransomware was from a reputable third party. Instead, they simply blocked the user's computer and demanded a fee for its release. Ransomware attackers have determined what they consider the optimal price point for payment to unblock a computer: the amount must be small enough that most victims will begrudgingly pay to have their systems unblocked, but large enough that when thousands of victims pay up, the attackers can garner a handsome sum. For individuals, the ransom is usually around \$500. However, for enterprises, the price has increased dramatically: the average ransom paid for one type of malware was more than \$1.3 million, and the average ransom for all ransomware has increased by one-third.⁵

Ransomware continues to be a serious threat to users. Threat actors have now shifted their sights to state and local governments that typically have weaker security. In 2019, two-thirds of ransomware attacks targeted state and local governments;⁶ to date, more than 350 of these governments have been the victims of successful attacks.⁷

Cryptomalware

In recent years, a more malicious form of ransomware has arisen. Instead of just blocking users from accessing the computer, it encrypts all the files on the device so that none of them can be opened. This is called **cryptomalware**. A screen appears telling the victims that their files are now encrypted, and a fee must be paid to receive a key to unlock them. In addition, threat actors have increased the urgency for payment: the cost for the key to unlock the cryptomalware increases every few hours or days. On some occasions, the threat actors claim that a growing number of the encrypted user files will be deleted until the ransom is paid; if the ransom is not paid promptly, the key to unlock the files can never be purchased. Figure 3-3 shows a cryptomalware message.



Figure 3-3 Cryptomalware message

In addition to encrypting files on the user's local hard drive, new variants of cryptomalware encrypt all files on *any* network or attached device connected to that computer. This includes secondary hard disk drives, USB hard drives, network-attached storage devices, network servers, and even cloud-based data repositories. Thus, if a user's computer in an enterprise is infected with cryptomalware, potentially *all* files for the enterprise—and not just those on one computer—can be locked.

Launch

Another category of malware is that which infects a computer to launch attacks on other computers. This includes a virus, worm, and bot.

Virus

There are two types of viruses: a file-based virus and a fileless virus.

File-Based Virus A biological virus is composed of tiny bits of genetic material enclosed by a protective shell. By themselves, viruses are lifeless and inert as they wait for a favorable environment in which to reproduce. When a virus encounters a host cell, the virus attaches itself to the outer wall of the cell, enters inside, travels to the cell's genome, merges with its genes, and then tricks the host's genome into making copies of itself.

NOTE 5

With early cryptomalware attacks, threat actors only delivered the decryption key fewer than half of the times that a ransom was paid. However, this resulted in some victims not paying a ransom since the risk was high of not getting the key. Threat actors have since learned that there is more to gain in the long run of making the key available after a ransom is paid. Today, when victims pay the ransom, a decryption tool is delivered 99 percent of the time. However, the key only works about 96 percent of the time. This is because specific variants of ransomware have a tendency to corrupt data when it is encrypted.⁹

A *file-based virus* is remarkably similar to a biological virus. It is malicious computer code that is attached to a file. A very large number of file types can contain a virus, and Table 3-1 lists some of the 50 different Microsoft Windows file types that can be infected with a virus. Like its biological counterpart, a file-based virus reproduces itself on the same computer. Strictly speaking, a file-based virus replicates itself (or an evolved copy of itself) without any human intervention.

NOTE 6

When the host cell is infected by a virus, the virus takes over the operation of that cell, converting it into a virtual factory to make more copies of the virus. The host cell rapidly produces millions of identical copies of the original virus. Biologists often say that viruses exist only to make more viruses.

NOTE 7

One of the first viruses found on a microcomputer was written for the Apple II in 1982. Rich Skrenta, a ninth-grade student in Pittsburgh, wrote "Elk Cloner," which displayed his poem on the screen after every 50th use of the infected floppy disk. Unfortunately, the virus leaked out and found its way onto the computer used by Skrenta's math teacher. In 1984, the mathematician Dr. Frederick Cohen introduced the term *virus* based on a recommendation from his advisor, who came up with the name from reading science fiction novels.

Table 3-1 Windows file types that can be infected

File extension	Description
DOCX or XLSX	Microsoft Office user documents
EXE	Executable program file
MSI	Microsoft installer file
MSP	Windows installer patch file
SCR	Windows screen saver
CPL	Windows Control Panel file
MSC	Microsoft Management Console file
WSF	Windows script file
PS1	Windows PowerShell script

Early viruses were relatively straightforward in how they infected files. One basic type of infection is the *appender infection*. The virus first attaches or appends itself to the end of the infected file. It then inserts at the beginning of the file a *jump* instruction that points to the end of the file, which is the beginning of the virus code. When the program is launched, the jump instruction redirects control to the virus. Figure 3-4 shows how an appender infection works.

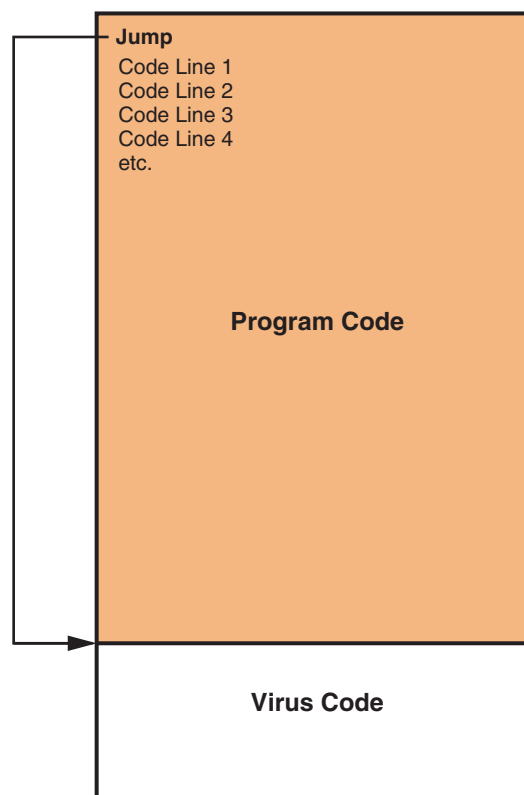


Figure 3-4 Appender infection

However, these types of viruses could be detected by virus scanners relatively easily. Later file-based viruses went to greater lengths to avoid detection; this type of virus is called an *armored file-based virus*. Some of the armored virus infection techniques include the *split infection* (it split the malicious code itself into several parts and then these parts are placed at random positions throughout the program code) and the *mutation* (the virus changes its internal code to one of a set number of predefined mutations whenever it is executed).

Each time the infected program is launched or the data file is opened—either by the user or the computer’s operating system (OS)—the virus first unloads a payload to perform a malicious action (such as to corrupt or delete files, prevent programs from launching, steal data to be sent to another computer, cause a computer to crash repeatedly, or turn off the computer’s security settings). Then the virus reproduces itself by inserting its code into another file, but only on the same computer. A virus can only replicate itself on the host computer where it is located; it cannot automatically spread to another computer by itself. Instead, it must rely on the actions of users to spread to other computers. Because viruses are attached to files, they are spread when a user transfers those files to other devices. For example, a user might send an infected file as an email attachment or copy an infected file to a USB flash drive and give the drive to another user. Once the virus reaches a new computer, it begins to infect it. Thus, a virus must have two carriers: a file to which it attaches and a human to transport it to other computers.

Fileless Virus A **fileless virus**, on the other hand, does not attach itself to a file. Instead, fileless viruses take advantage of native services and processes that are part of the OS to avoid detection and carry out its attacks. These native services used in a fileless virus are called *living-off-the-land binaries (LOLBins)*. For a computer running Microsoft Windows, some of commonly exploited LOLBins are listed in Table 3-2.

Table 3-2 Microsoft Windows common LOLBins

Name	Description
PowerShell	A cross-platform and open source task automation and configuration management framework
Windows Management Instrumentation (WMI)	A Microsoft standard for accessing management information about devices
.NET Framework	A free, cross-platform, open source developer platform for building different types of applications
Macro	A series of instructions that can be grouped together as a single command to automate a complex set of tasks or a repeated series of tasks, can be written by using a macro scripting language, such as Visual Basic for Applications (VBA), and is stored within the user document (such as in an Excel .xlsx workbook or Word .docx file)

Unlike a file-based virus, a fileless virus does not infect a file and wait for that file to be launched. Instead, the malicious code of a fileless virus is loaded directly in the computer’s random access memory (RAM) through the LOLBins and then executed.

There are several advantages of a fileless virus over a file-based virus:

- **Easy to infect.** A fileless virus does not require that a specific type of file be stored on the computer’s hard drive for the virus to infect. Instead, a common delivery method is through malicious webpages that the user visits. These pages silently send a script to the victim’s web browser, which invokes a scripting language such as JavaScript. The browser passes instructions to a LOLBin such as PowerShell, which reads and executes the commands.

NOTE 8

Some armored viruses scan for the presence of files that security researchers typically use. If those files are present, the virus assumes it is being examined for weaknesses and automatically self-destructs by deleting itself.

NOTE 9

Several similarities between biological and computer viruses exist: both must enter their host passively (by relying on the action of an outside agent), both must be on the correct host (a horse virus cannot make a human sick, just as an Apple Mac virus cannot infect a Windows computer), both can only replicate when inside the host, both may remain dormant for a period of time, and both types of viruses replicate at the expense of the host.

NOTE 10

Microsoft Windows LOLBins are often categorized into binaries (programs that end in .EXE), libraries (.DLL), and scripts (.VBS). By some estimates 115 Windows LOLBins can be exploited by a fileless virus, while UNIX/Linux systems have 185 LOLBins.

- *Extensive control.* Several LOLBins have extensive control and authority on a computer. For example, PowerShell has full access to the core OS of a Windows computer, so it can undermine existing security features. PowerShell can also manipulate user accounts and password protection.
- *Persistent.* A program that is loaded into RAM for execution will terminate once the computer is shut down or rebooted. However, fileless viruses often write their script into the *Windows Registry*, which is a database that stores settings for the Windows OS and application programs. Each time the computer is restarted or on a set schedule, the script of the fileless virus is again launched.
- *Difficult to detect.* Files that are infected with a file-based virus can be scanned by an antivirus tool for detection. However, because a fileless virus loads into RAM, no telltale file can be scanned. Also, by using LOLBins, there is no evidence of other tools being used. And some LOLBins like PowerShell run in a section of system memory that cannot be queried or searched, making its activities virtually impossible to detect.
- *Difficult to defend against.* To fully defend against a fileless virus, it would be necessary to turn off all the potential LOLBins, which would cripple the OS and cause it to not properly function. Also, these LOLBins are loaded by default when the OS starts so that any attempt to turn selected LOLBins off would already be too late.

Worm

A second type of malware that has as its primary purpose to spread is a worm. A **worm** is a malicious program that uses a computer network to replicate. (Worms are sometimes called *network viruses*.) A worm is designed to enter a computer through the network and then take advantage of a vulnerability in an application or an OS on the host computer. Once the worm has exploited the vulnerability on one system, it immediately searches for another computer on the network that has the same vulnerability.

NOTE 11

One of the first wide-scale worm infections occurred in 1988. This worm exploited a misconfiguration in a program that allowed commands emailed to a remote system to be executed on that system. The worm also carried a payload containing a program that attempted to determine user passwords. Almost 6,000 computers, or 10 percent of the devices connected to the Internet at that time, were affected. The threat actor responsible was later convicted of federal crimes in connection with this incident.

Early worms were relatively benign and designed simply to spread quickly but not corrupt the systems they infected. These worms slowed down the network through which they were transmitted by replicating so quickly that they consumed all network resources. Today's worms can leave behind a payload on the systems they infect and cause harm, much like a virus. Actions that worms have performed include deleting files on the computer or allowing the computer to be remotely controlled by an attacker.

NOTE 12

Although viruses and worms are said to be automatically self-replicating, *where* they replicate is different. A virus self-replicates *on* the host computer but does not spread to other computers by itself. A worm self-replicates *between* computers (from one computer to another).

Bot

Another popular payload of malware is software that allows the infected computer to be placed under the remote control of an attacker for the purpose of launching attacks. This infected robot computer is known as a **bot** or *zombie*. When hundreds, thousands, or even millions of bot computers are gathered into a logical computer network, they create a *botnet* under the control of a *bot herder*.

NOTE 13

Due to the multitasking capabilities of modern computers, a computer can act as a bot while carrying out the tasks of its regular user. Users are completely unaware that their computer is being used for malicious activities.

Table 3-3 lists some of the attacks that can be generated through botnets.

Table 3-3 Uses of botnets

Type of attack	Description
Spamming	Botnets are widely recognized as the primary source of spam email. A botnet consisting of thousands of bots enables an attacker to send massive amounts of spam.
Spreading malware	Botnets can be used to spread malware and create new bots and botnets. Bots can download and execute a file sent by the attacker.
Ad fraud	Threat actors earn money by generating a high number of “clicks” on advertisements at targeted websites, using a bot to mimic the mouse clicks of a user.
Mining cryptocurrencies	Also called “cryptomining,” this is a process in which transactions for various forms of cryptocurrency are verified, earning the “miner” a monetary reward. Botnets combine the resources of millions of bots for mining cryptocurrencies.

Infected bot computers receive instructions through a **command and control (C&C)** structure from the bot herders regarding which computers to attack and how. There are a variety of ways for this communication to occur, including the following:

- A bot can receive its instructions by automatically signing in to a bot-herding website where information has been placed that the bot knows how to interpret as commands.
- Bots can sign in to a third-party website; this has an advantage of the bot herder not needing to have a direct affiliation with that website.
- Commands can be sent via blogs, specially coded attack commands through posts on Twitter, or notes posted in Facebook.
- Bot herders are increasingly using a “dead drop” C&C mechanism by setting up a Google Gmail email account and then creating a draft email message that is never sent but contains commands the bot receives when it logs in to Gmail and reads the draft. Because the email message is never sent, there is no record of the commands. All Gmail transmissions are protected so that outsiders cannot view them.

Snoop

Another category of malware “snoops” or spies on its victims. The two common types of snooping malware are spyware and keyloggers.

Spyware

Spyware is tracking software that is deployed without the consent or control of the user. Spyware can secretly monitor users by collecting information without their approval through the computer’s resources, including programs already installed on the computer, to collect and distribute personal or sensitive information. Table 3-4 lists different technologies used by spyware.

Table 3-4 Technologies used by spyware

Technology	Description	Impact
Automatic download software	Downloads and installs software without the user’s interaction	Could install unauthorized applications
Passive tracking technologies	Gathers information about user activities without installing any software	Could collect private information such as websites a user has visited
System modifying software	Modifies or changes user configurations, such as the web browser home page or search page, default media player, or lower-level system functions	Changes configurations to settings that the user did not approve
Tracking software	Monitors user behavior or gathers information about the user, sometimes including personally identifiable or other sensitive information	Could collect personal information that can be shared widely or stolen, resulting in fraud or identity theft



CAUTION

Not all spyware is necessarily malicious. For example, spyware monitoring tools can help parents keep track of the online activities of their children.

Keylogger

Another type of spying is done with a **keylogger** that silently captures and stores each keystroke that a user types on the computer's keyboard. The threat actor can then search the captured text for any useful information such as passwords, credit card numbers, or personal information. A keylogger can be a software program or a small hardware device.

Software keyloggers are programs installed on the computer that silently capture sensitive information. However, software keyloggers, which conceal themselves so that the user cannot detect them, go far beyond capturing a user's keystrokes. These programs can also capture everything on the user's screen and silently turn on the computer's web camera to record images of the user. A software keylogger is illustrated in Figure 3-5.

NOTE 14

An advantage of software keyloggers is that they do not require physical access to the user's computer because they can be installed remotely. They can routinely send captured information back to the attacker through the victim's own Internet connection.

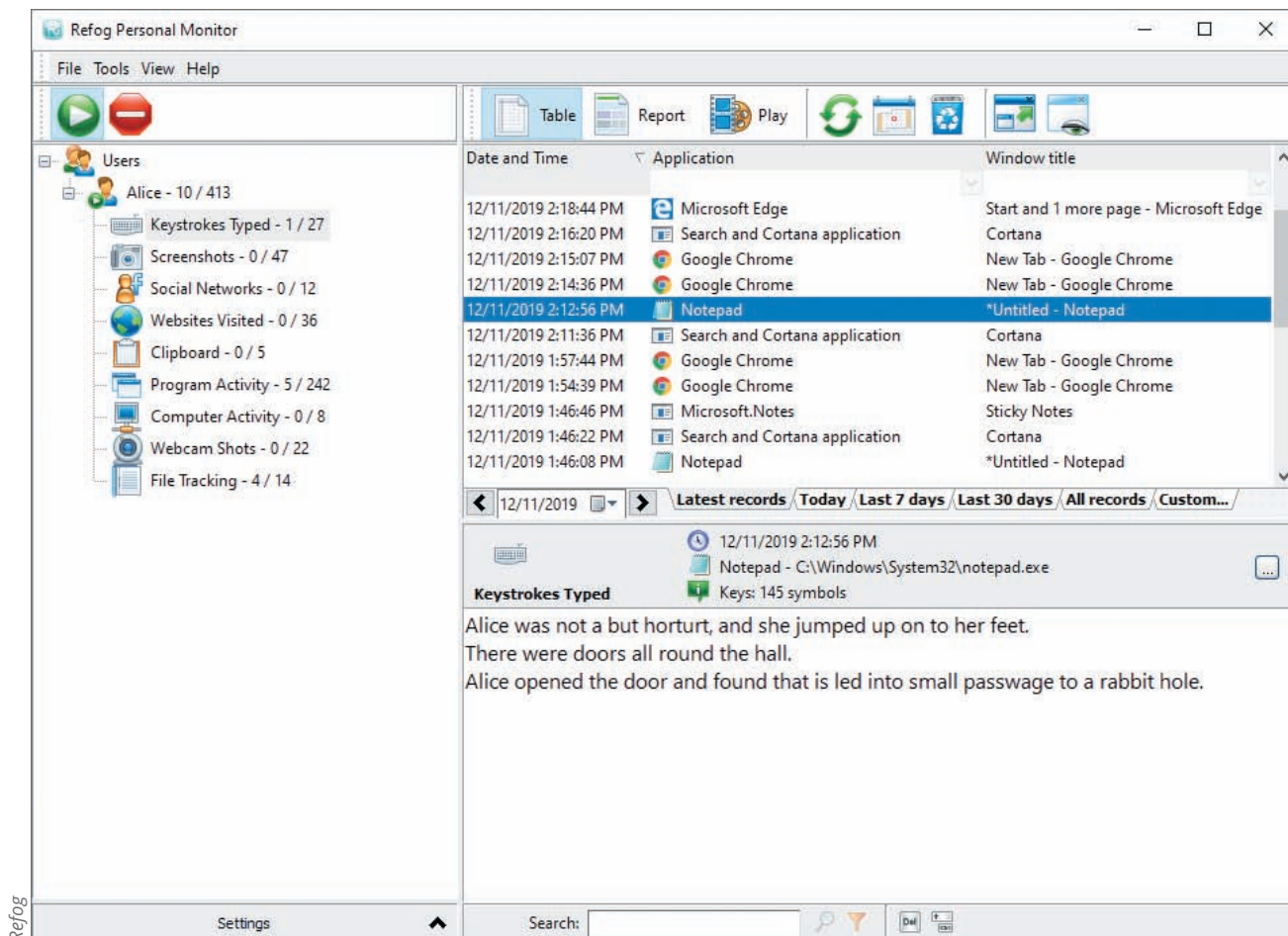


Figure 3-5 Software keylogger

For computers that are in a public location such as a library or computer lab but are “locked down” so that no software can be installed, a hardware keylogger can be used instead. These keyloggers are hardware devices inserted between the computer keyboard connection and USB port, as shown in Figure 3-6. Because the device resembles an ordinary

keyboard plug and the computer keyboard USB port is often on the back of the computer, a hardware keylogger can easily go undetected. In addition, the device is beyond the reach of the computer's antimalware scanning software and thus raises no alarms. A disadvantage of a hardware keylogger is that the threat actor must install and then later return to physically remove the device in order to access the information it has stored, each time being careful not to be detected.

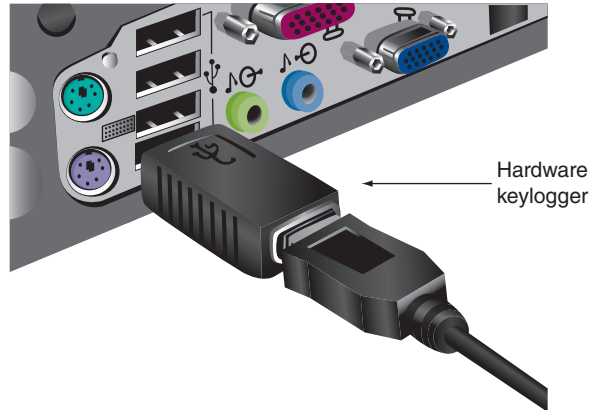


Figure 3-6 Hardware keylogger

Deceive

Some malware attempts to deceive the user and hide its true intentions. Software in this category includes potentially unwanted programs (PUPs), Trojans, and remote access Trojans (RATs).

Potentially Unwanted Program (PUP)

A broad category of software that is often more annoying than malicious is called **potentially unwanted programs (PUPs)**. A PUP is software that the user does not want on their computer. PUPs often become installed along with other programs and are the result of the user overlooking the default installation options on software downloads, as seen in Figure 3-7.



Source: Oracle Corporation

Figure 3-7 Default installation options

NOTE 15

The term PUP was created by an Internet security company because marketing firms objected to having their products being called “spyware.”

PUPs may include software that is pre-installed on a new computer or smartphone and cannot be easily removed (if at all). Other examples of PUPs are advertising that obstructs content or interferes with web browsing, pop-up windows, pop-under windows, search engine hijacking, home page hijacking, toolbars with no value for the user, and settings that redirect to competitors’ websites, alter search results, and replace ads on webpages.

Trojan

According to ancient legend, the Greeks won the Trojan War by hiding soldiers in a large hollow wooden horse that was presented as a gift to the city of Troy. Once the horse was wheeled into the fortified city, the soldiers crept out of the horse during the night and attacked the unsuspecting defenders.

A computer **Trojan** is an executable program that masquerades as performing a benign activity but also does something malicious. For example, a user might download what is advertised as a calendar program, yet in addition to installing the calendar, it also installs malware that scans the system for credit card numbers and passwords, connects through the network to a remote system, and then transmits that information to the attacker.

Remote Access Trojan (RAT)

A special type of Trojan is a **remote access Trojan (RAT)**. A RAT has the basic functionality of a Trojan but also gives the threat agent unauthorized remote access to the victim’s computer by using specially configured communication protocols. This creates an opening into the victim’s computer, allowing the threat agent unrestricted access. The attacker can not only monitor what the user is doing but also change computer settings, browse and copy files, and even use the computer to access other computers connected on the network.

Evade

The final category of malware attempts to help malware or attacks evade detection. This includes backdoor, logic bomb, and rootkit.

Backdoor

A **backdoor** gives access to a computer, program, or service that circumvents any normal security protections. Backdoors installed on a computer allow the attacker to return later and bypass security settings.

Creating a legitimate backdoor is a common practice by developers, who may need to access a program or device on a regular basis, yet do not want to be hindered by continual requests for passwords or other security approvals. The intent is for the backdoor to be removed once the application is finalized. However, in some instances, backdoors have been left installed, and attackers have used them to bypass security.

Logic Bomb

A **logic bomb** is computer code that is typically added to a legitimate program but lies dormant and evades detection until a specific logical event triggers it. Once it is triggered, the program then deletes data or performs other malicious activities.

NOTE 16

Many logic bombs have been planted by disgruntled employees. For example, a Maryland government employee tried to destroy the contents of more than 4,000 servers by planting a logic bomb script that was scheduled to activate 90 days after he was terminated.

Logic bombs are difficult to detect before they are triggered. This is because logic bombs are often embedded in very large computer programs, some containing hundreds of thousands of lines of code, and a trusted employee can easily insert a few lines of computer code into a long program without anyone detecting it. In addition, these programs are not routinely scanned for containing malicious actions.

Rootkits

A **rootkit** is malware that can hide its presence and the presence of other malware on the computer. It does this by accessing “lower layers” of the operating system or even using undocumented functions to make alterations. This enables the rootkit and any accompanying software to become undetectable by the operating system and common antimalware scanning software that is designed to seek and find malware.

NOTE 17

The risks of rootkits are significantly diminished today due to protections built into operating systems. These protections include preventing unauthorized kernel drivers from loading, stopping modifications to certain kernel areas used by rootkits to hide, and preventing rootkits from modifying the bootloader program.

TWO RIGHTS & A WRONG

1. It is a common tactic for cryptomalware attackers to not send the decryption key after the ransom has been paid.
2. Fileless viruses take advantage of native services and processes that are part of the operating system (OS) to avoid detection and carry out its attacks, and these native services used in a fileless virus are called living-off-the-land binaries (LOLBins).
3. A remote access Trojan (RAT) can monitor what the user is doing, change computer settings, browse and copy files, and use the computer to access other computers connected on the network.

See Appendix B for the answer.

APPLICATION ATTACKS**CERTIFICATION**

1.3 Given a scenario, analyze potential indicators associated with application attacks.

Attacks using malware typically add malicious software to an endpoint. Another category of attacks specifically targets software applications that are already installed and running on the device. These attacks look for vulnerabilities in the application or manipulate the application in order to compromise it. While on occasion threat actors target applications running on a user's endpoint like a personal computer, more often, their sights are set on compromising applications that can provide many more potential victims than a single computer user. The more common targets of attackers using application attacks are Internet web servers.

A web server provides services that are implemented as “web applications” through software applications running on the server. A typical web application infrastructure is shown in Figure 3-8. The client's web browser makes a request using the Hypertext Transport Protocol (HTTP) to a web server, which may be connected to one or more web application servers. These application servers run the specific “web apps,” which in turn are directly connected to database servers on the internal network. Information from these database servers is retrieved and returned to the web server so that the information can be sent back to the user's web browser.

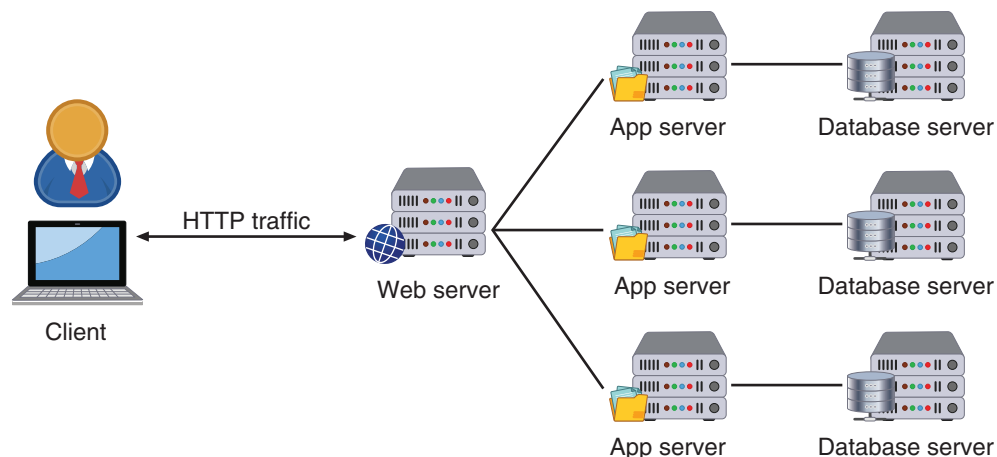


Figure 3-8 Web server application infrastructure

The multiple elements in a web application infrastructure provide multiple attack points: a single vulnerability could expose many other users who are accessing the web server. An attack could also compromise backend databases and app servers, and the connected network infrastructure.

Application attacks include scripting attacks, injection attacks, request forgery attacks, and replay attacks. These attacks typically target how the applications function. In addition, attacks directly focused on vulnerabilities in the software applications are common.

Scripting

Most web applications create dynamic content based on input from the user. Figure 3-9 illustrates a fictitious web application that allows friends to share their favorite bookmarks with each other online. Users can enter their name, a description, and the URL of the bookmark and then receive a personalized “Thank You” screen. In Figure 3-10, the code that generates the “Thank You” screen is illustrated.

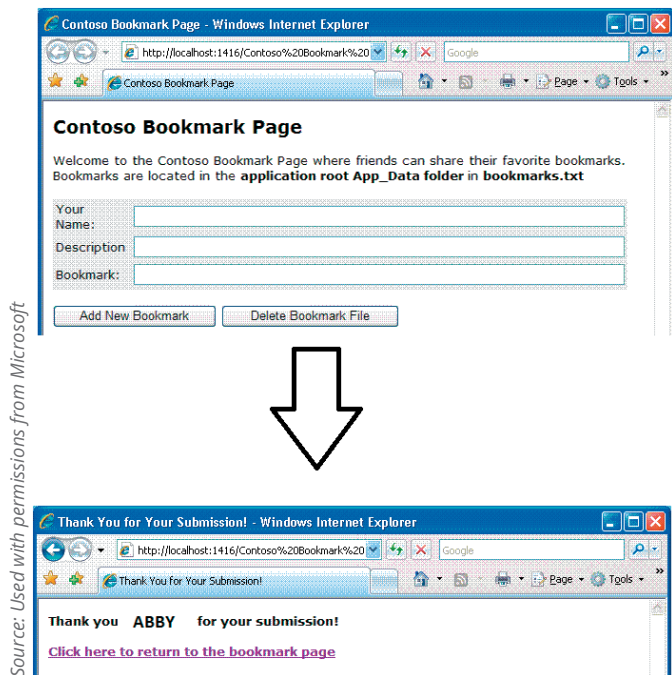


Figure 3-9 Bookmark page that accepts user input

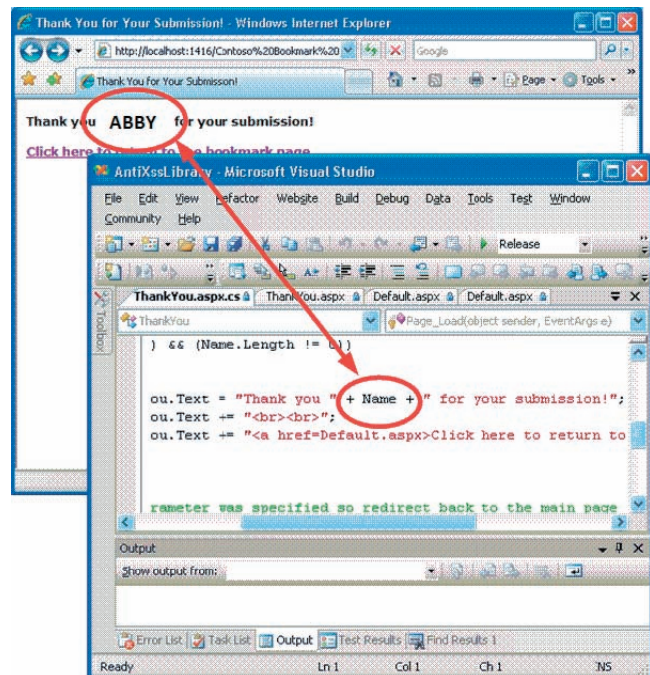


Figure 3-10 Input used in response

NOTE 18

The term *cross-site scripting* refers to an attack using scripting that originates on one site (the web server) to impact another site (the user's computer).

In a **cross-site scripting (XSS)** attack, a website that accepts user input without validating it (called *sanitizing*) and uses that input in a response can be exploited. In the previous example, the input that the user enters for *Name* is not verified but instead is automatically added to a code segment that becomes part of an automated response. An attacker can take advantage of this in an XSS attack by tricking a valid website into feeding a malicious script to another user's web browser, which will then execute it.

Injection

In addition to cross-site attacks on web server applications, attacks called **injections** also introduce new input to exploit a vulnerability. One of the most common injection attacks, called **SQL injection**, inserts statements to manipulate a database server. SQL stands for **Structured Query Language**, a language used to view and manipulate data that is stored in a relational database. SQL injection targets SQL servers by introducing malicious commands into them.

Consider a webpage that offers a solution for users who have forgotten their password. An online form asks users to enter their username, which is also their email address that is already on file. The submitted email address is compared to the stored email address, and if they match, a reset URL is emailed to that address.

If the email address entered by the user into the form is stored in the variable *\$EMAIL*, then the underlying SQL statement to retrieve the stored email address from the database would be similar to this:

```
SELECT fieldlist FROM table WHERE field = '$EMAIL'
```

The *WHERE* clause is meant to limit the database query to only display information when the condition is considered true (that is, when the email address in *\$EMAIL* matches an address in the database).

An attacker using an SQL injection attack would begin by first entering a fictitious email address on this webpage that included a single quotation mark as part of the data, such as *braden.thomas@fakemail.com'*. If the message *E-mail Address Unknown* is displayed, it indicates that user input is being properly filtered and an SQL attack cannot be rendered on the site. However, if the error message *Server Failure* is displayed, it means that the user input is not being filtered and all user input is sent directly to the database. This is because the *Server Failure* message is due to a syntax error created by the additional single quotation mark in the fictitious email address.

Armed with the knowledge that input is sent unfiltered to the database, the attacker knows that anything he enters as a username in the form would be sent to and then processed by the SQL database. Now, instead of entering a user name, the attacker would enter this command, which would let him view all the email addresses in the database: *whatever'* or *'a'='a'*. This command is stored in the variable *\$EMAIL*. The expanded SQL statement would read

```
SELECT fieldlist FROM table WHERE field = 'whatever' or 'a'='a'
```

These values are the following:

- *'whatever'*. This can be anything meaningless.
- *or*. The SQL *or* means that as long as either of the conditions are true, the entire statement is true and will be executed.
- *'a'='a'*. This is a statement that will always be true.

Because *'a'='a'* is always true, the *WHERE* clause is also true. It is not limited as it was when searching for a single email address before it would become true. The result can be that *all* user email addresses will then be displayed.

By entering crafted SQL statements as user input, information from the database can be extracted or the existing data can be manipulated. SQL injection statements that can be entered and stored in *\$EMAIL*, and their pending results are shown in Table 3-5.

Table 3-5 SQL injection statements

SQL injection statement	Result
<i>'whatever' AND email IS NULL;</i>	Determine the names of different fields in the database
<i>'whatever' AND 1= (SELECT COUNT(*) FROM tablename);</i>	Discover the name of the table
<i>'whatever' OR full name LIKE '%Mia%';</i>	Find specific users
<i>'whatever'; DROP TABLE members;</i>	Erase the database table
<i>'whatever'; UPDATE members SET email = 'attacker-email@evil.net' WHERE email = 'Mia@good.com';</i>	Mail password to attacker's email account

In addition to using SQL to view and manipulate data that is stored in a relational database, other types of databases not using SQL (called *NoSQL databases*) are also used. One popular type of NoSQL database manipulates data using the **eXtensible Markup Language (XML)**. Like the markup language Hyper Text Markup Language (HTML) used for webpages, XML is not a processing language but instead is designed to store information. A NoSQL database that uses XML for data manipulation is also subject to an injection attack like SQL injection if the input is not sanitized. This is called an **XML injection**.

Request Forgery

Although some attacks have confusing names, that is not the case with the category of *request forgery*. As its name suggests, it is a request that has been fabricated. There are two types of request forgeries. These are a cross-site request forgery (CSRF) and a server-site request forgery (SSRF).

Cross-Site Request Forgery (CSRF)

A **cross-site request forgery (CSRF)** takes advantage of an authentication “token” that a website sends to a user’s web browser. If a user is currently authenticated on a website and is then tricked into loading another webpage, the new page inherits the identity and privileges of the victim, who may then perform an undesired function on the attacker’s behalf. Figure 3-11 illustrates a cross-site request forgery. Because a CSRF takes place on the client site, it is sometimes called a **client-side request forgery**.

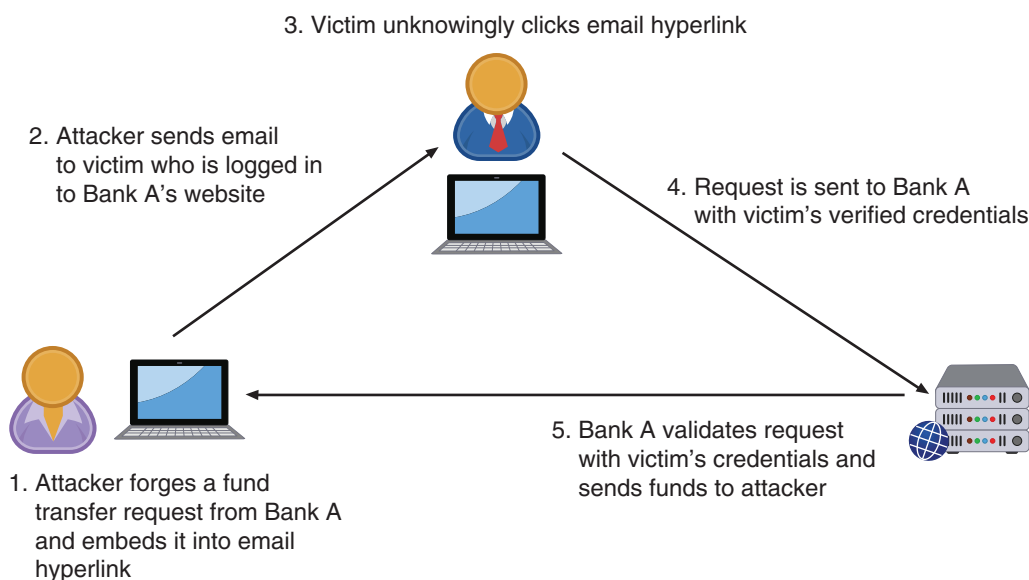


Figure 3-11 Cross-site request forgery

NOTE 19

In other words, in a CSRF attack a *request* to a website is not from the authentic user but is a *forgery* that involves *crossing sites*.

Server-Side Request Forgery (SSRF)

A **server-side request forgery (SSRF)** takes advantage of a trusting relationship between web servers (as opposed to a CSRF, which manipulates the trust from a user’s browser to a server). SSRF attacks exploit how a web server processes external information received from another server. Some web applications are designed to read information from or write information to a specific URL. If an attacker can modify that target URL, they can potentially extract sensitive information from the application or inject untrusted input into it. Table 3-6 outlines the differences between a CSRF and a SSRF.

Table 3-6 CSRF and SSRF differences

Attack name	Attack target	Purpose of attack
CSRF	User	Force target to take action for attacker while pretending to be authorized user
SSRF	Web server	Gain access to sensitive data or inject harmful data

Replay

Whereas some attacks try to capture data sent between two users, a **replay** attack copies data and then uses it for an attack. Replay attacks are commonly used against digital identities—after intercepting and copying data, the threat actor retransmits selected and edited portions of the copied communications later to impersonate the legitimate user. Many digital identity replay attacks are between a user and an authentication server.

Attacks on Software

Other attacks are directly focused on vulnerabilities in the software applications. These include exploiting memory vulnerabilities, improper exception and error handling, and external software components.

Memory Vulnerabilities

Several attacks are directed at vulnerabilities associated with how a program uses RAM. These are often the result of poor techniques (or laziness) by the software developer.

Some memory-related attacks are called **resource exhaustion attacks** because they “deplete” parts of memory and thus interfere with the normal operation of the program in RAM. This may allow the threat actor access to the underlying OS in a way that it could be exploited by bypass security settings. An example is a **memory leak**. An application normally dynamically allocates memory, but due to a programming error, it may not free that memory when finished using it. An attacker can then take advantage of the unexpected program behavior resulting from a low memory condition.

Other memory-related attacks attempt to manipulate memory contents. Again, these are made possible by poor programming practices. These types of attacks include buffer overflow attacks and integer overflow attacks.

Buffer Overflow Consider a teacher working in his office who manually grades a lengthy written examination by marking incorrect answers with a red pen. Because he is frequently interrupted in his grading by students, the teacher places a ruler on the test question he is currently grading to indicate his “return point,” or the point at which he should resume the grading. Suppose that two devious students enter his office as he is grading examinations. While one student distracts him, the second student silently slides the ruler down from question 4 to question 20. When the teacher returns to grading, he will resume at the wrong “return point” and not look at the answers for questions 4 through 19.

This scenario is similar to how a buffer overflow attacker attempts to compromise a computer. A storage buffer on a computer typically contains the memory location of the software program that was being executed when another function interrupted the process; that is, the storage buffer contains the “return address” where the computer’s processor should resume once the new process has finished. Attackers can substitute their own “return address” in order to point to a different area in the computer’s memory that contains their malware code.

A **buffer overflow attack** occurs when a process attempts to store data in RAM beyond the boundaries of a fixed-length storage buffer. This extra data overflows into the adjacent memory locations (a *buffer overflow*). Because the storage buffer typically contains the “return address” memory location of the software program being executed when another function interrupted the process, an attacker can overflow the buffer with a new address pointing to the attacker’s malware code. A buffer overflow attack is shown in Figure 3-12.

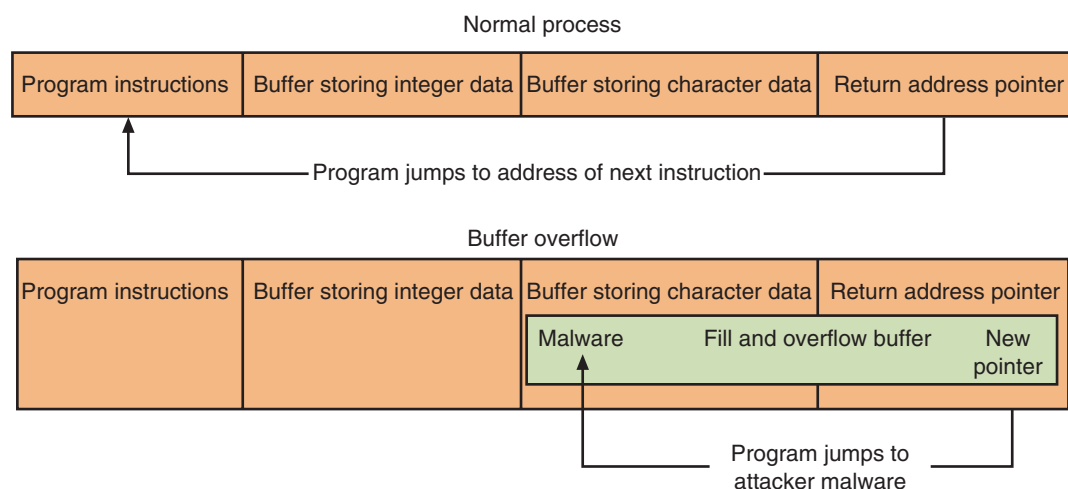


Figure 3-12 Buffer overflow attack

NOTE 20

The “return address” is not the only element that can be altered in a buffer overflow attack, but it is one of the most commonly altered elements.

Integer Overflow Consider a digital clock that can display the hours only as 1 to 12. What happens when the time moves past 12:59? The clock then “wraps around” to the lowest hour value of 1 again.

On a computer, an *integer overflow* is the condition that occurs when the result of an arithmetic operation—such as addition or multiplication—exceeds the maximum size of the integer type used to store it. When this integer overflow occurs, the interpreted value then wraps around from the maximum value to the minimum value. For example, an eight-bit signed integer has a maximum value of 127 and a minimum value of -128. If the value 127 is stored in a variable and 1 is added to it, the sum exceeds the maximum value for this integer type and wraps around to become -128.

In an **integer overflow attack**, an attacker changes the value of a variable to something outside the range that the programmer had intended by using an integer overflow. This type of attack could be used in the following situations:

- An attacker could use an integer overflow attack to create a buffer overflow. If an integer overflow could be introduced during the calculations for the length of a buffer when a copy is occurring, it could result in a buffer that is too small to hold the data. An attacker could then use this to create a buffer overflow attack.
- A program that calculates the total cost of items purchased would use the number of units sold times the cost per unit. If an integer overflow were introduced when tallying the number of items sold, it could result in a negative value and a resulting negative total cost, indicating that a refund is due the customer.
- A large positive value in a bank transfer could be wrapped around by an integer overflow attack to become a negative value, which could then reverse the flow of money: instead of adding this amount to the victim’s account, it could withdraw that amount and later transfer it to the attacker’s account.

NOTE 21

An extreme example of an integer overflow attack would be withdrawing \$1 from an account that has a balance of 0, which could cause a new balance of \$4,294,967,295!

Improper Exception Handling

Other attacks on software, like memory vulnerabilities, are the result of poor coding on the part of software developers. This is commonly the case when the program does not properly check for exceptions that may occur when the program is running.

Software that allows the user to enter data but has **improper input handling** features does not filter or validate user input to prevent a malicious action. For example, a webpage on a web server with improper input handling that asks for the user’s email address could allow an attacker to instead enter a direct command that the server would then execute.

Other software may not properly trap an error condition and thus provides an attacker with underlying access to the system. This is known as incorrect **error handling**. Suppose an attacker enters a string of characters that is much longer than expected. Because the software has not been designed for this event, the program could crash or suddenly halt its execution and then display an underlying OS prompt, giving an attacker access to the computer.

Another improper exception handling situation is a NULL **pointer/object dereference**. (A *dereference* obtains from a pointer the address of a data item held in another location.) When an application dereferences a pointer that it expects to be valid but instead has a value of NULL, it typically will cause a program to crash or exit. A NULL pointer/object dereference can occur through a number of flaws, including simple programming omissions.

A NULL pointer/object dereference can also be the result of a race condition. A **race condition** in software occurs when two concurrent threads of execution access a shared resource simultaneously, resulting in unintended consequences. For example, in a program with two threads that have access to the same location in memory, Thread #1 stores the value A in that memory location. But since Thread #2 is also executing, it may overwrite the same memory location with the value Z. When Thread #1 retrieves the value stored, it is given Thread #2’s Z instead of its own A. The software checks the state of a resource before using that resource, but the resource’s state can change between the check and the use in a way that invalidates the results of the check. This is called a **time of check/time of use** race condition. This condition is often security-relevant: a threat actor who can influence the state of the resource between check and use can negatively impact a number of shared resources such as files, memory, or variables in multithreaded programs.



CAUTION

Time of check/time of use often appears as time of check to time of use (TOCTTOU). A typo of TOCTTOU is TOCCTOU and has been used in some influential documents, so the typo is repeated fairly frequently.

Attacks on External Software Components

In addition to attacking the software directly, threat actors also target external software components. These include the following:

- *Application program interface (API).* An *application program interface (API)* is a link provided by an OS, web browser, or other platform that allows a developer access to resources at a high level. An example of an API is when a user visits a website and the message “This site wants to know your location” appears. The website is attempting to use geolocation API available in the web browser. APIs relieve the developer from the need to write code for specific hardware and software. Because APIs provide direct access to data and an entry point to an application’s functions, they are attractive targets for attackers looking for vulnerabilities in the API in an **application program interface (API) attack**.
- *Device driver.* A *device driver* is software that controls and operates an external hardware device that is connected to a computer. Device drivers are specific to both the OS and the hardware device. Threat actors may attempt to alter a device driver for use in an attack (called **device driver manipulation**). An attacker may use **shimming**, or transparently adding a small coding library that intercepts calls made by the device and changes the parameters passed between the device and the device driver. This **refactoring** (changing the design of existing code) can be difficult to detect yet serves as a real threat.
- *Dynamic-link library (DLL).* A *dynamic-link library (DLL)* is a repository of both code and data that can be used by more than one program at the same time. For example, in the Windows operating systems, the Comdlg32.DLL performs common dialog box related functions. Attackers use a technique called **DLL injection** for inserting code into a running process through a DLL to cause a program to function in a different way than intended.

NOTE 22

API vulnerabilities are particularly attractive because they can have a broad impact and may take a long time to discover. In 2018, Facebook found a vulnerability in its API code that made it possible for attackers to steal access tokens and take over the accounts of 30 million users. It took Facebook 14 months before they discovered the API vulnerability. It is predicted that by 2022, API abuses will become the most common type of web application attack resulting in a data breach.¹⁰

TWO RIGHTS & A WRONG

1. In an XSS attack, a website that accepts user input without sanitizing it and uses that input in a response can be exploited.
2. An SSRF takes advantage of a trusting relationship between a web browser and web servers.
3. A time of check/time of use is a vulnerability that causes a race condition.

See Appendix B for the answer.

ADVERSARIAL ARTIFICIAL INTELLIGENCE ATTACKS

CERTIFICATION

1.2 Given a scenario, analyze potential indicators to determine the type of attack.

Artificial intelligence is being used worldwide in a wide variety of applications, ranging from the mundane to the very sophisticated. Cybersecurity is likewise using these innovative technologies to enhance the detection of malicious behavior and advanced threats. However, there are significant vulnerabilities and risks with using these new tools. Understanding them includes knowing what the tools are and what they can do, how these tools are used in cybersecurity, and their potential risks.

What Are Artificial Intelligence (AI) and Machine Learning (ML)?

Consider the following scenario. Junaid's team leader asks him to fly to another branch of the company tomorrow morning to assist with its new direct marketing campaign. He agrees and books online an airplane reservation for early the next morning. As Junaid awakens, his smartphone buzzes. His phone alerts him about the weather at his destination and makes recommendations about the clothes to pack for his trip. It also tells him what time

to leave for the airport based on local traffic and the length of time needed to pass through airport security. When Junaid pulls his car out of his driveway, he receives another message on his phone explaining that an accident is slowing traffic on the main road to the airport and directing him to take an alternate route. After his flight, Junaid arrives at the hotel and suddenly remembers that he volunteered to help plan a birthday party for his niece on Saturday. Using the smart speaker in his hotel room, he logs in to his account and tells the voice assistant what he needs. After a few minutes, he has arranged for the party invitations to be sent to select individuals in his contact list, ordered a birthday present based on what is popular with other children the same age as his niece, and has set a reminder for him to pick up the cake after he arrives back home. The next morning, Junaid arrives at the remote office to help with a direct marketing campaign. He begins by demonstrating to a college intern how to use the company's new smart assistant to segment their customers into groups to receive targeted messaging in order to increase the response rates.

Just a few years ago, this scenario would have been nothing more than science fiction. Today, however, it is commonplace and occurs multiple times every day in our work and personal lives. This is based on tools that provide genuine human-to-machine interaction.

The foundation behind this interaction is called *artificial intelligence (AI)*. Although definitions of AI vary, at its core, AI may be defined as technology that imitates human abilities. Although the practical use of AI has only appeared recently, it has a long history dating back to the first large-scale computers.

A recognized subset of AI is *machine learning (ML)*. Humans learn by direct commands of someone older and wiser, but this requires the other person to always be present. Humans also learn through experiences (such as touching a hot stove results in a painful burn). ML is defined as "teaching" a technology device to "learn" by itself without the continual instructions of a computer programmer. ML also involves learning through repeated experience: that is, if something attempted does not work, then it determines how it could be changed to make it work.

NOTE 23

The original goal of AI was to make computers more useful and more capable of independent reasoning. Most historians trace the birth of AI to a Dartmouth research project in 1956 that explored problem solving and symbolic methods. In the 1960s, the U.S. DoD became interested in this research and worked on training computers to imitate human reasoning. Some projects that came from the DoD were a street-mapping project in the 1970s and intelligent personal assistants in the early 2000s.

NOTE 24

The relationship between AI and ML is AI applies ML to solve problems without being explicitly programmed what to do.

Uses in Cybersecurity

Cybersecurity AI allows organizations to detect, predict, and respond to cyberthreats in real time using ML. AI is already being used broadly in cybersecurity defenses. Virtually all email systems use some type of AI to block phishing attacks by examining obvious clues (such as the URL of the link that the victim is being tempted to click) but also subtle clues (such as the tense and voice of words in the email). AI using ML can analyze these to continually learn to distinguish and block phishing emails while allowing genuine emails to reach the user's inbox.

The prime advantages of using AI to combat threats are continual learning and greater speed in response. By relying on data from previous similar attacks, AI can predict and prevent future attacks. ML learning algorithms can quickly apply complex pattern recognition techniques to spot and thwart attacks much faster than humans can.

The use of AI in cybersecurity is widespread. About one in five organizations used cybersecurity AI before 2019, increasing to two out of three organizations planning to deploy it by the end of 2020. Telecommunications providers use cybersecurity AI more than any other sector: 80 percent of telecom companies said that they would not be able to respond to cyberattacks without using AI.¹¹ Figure 3-13 illustrates where AI cybersecurity is used in specific areas within an enterprise.

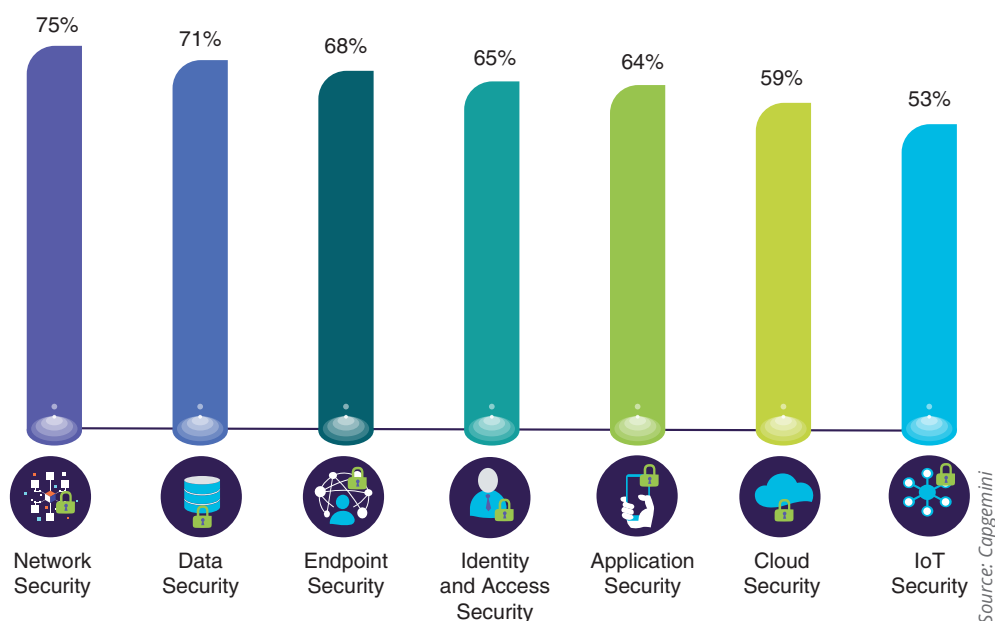


Figure 3-13 How AI cybersecurity is used

Risks in Using AI and ML in Cybersecurity

Although the use of AI in cybersecurity is growing, there are risks associated with using AI and ML in cybersecurity. This is called **adversarial artificial intelligence**. The first risk is the **security of the ML algorithms**. Just as all hardware and software is subject to being infiltrated by threat actors, AI-powered cybersecurity applications and their devices likewise have vulnerabilities. These could be attacked and compromised, allowing threat actors to alter algorithms to ignore attacks, much like a rootkit can instruct an OS to ignore malicious actions.

Another risk is **tainted training data for machine learning**. Attackers can attempt to alter the training data that is used by ML in order to produce false negatives to cloak themselves.



CAUTION

Another concern is that threat actors themselves will turn to using AI for attacks in order to circumvent defenses.

TWO RIGHTS & A WRONG

1. Artificial intelligence (AI) may be defined as technology that imitates human abilities.
2. AI is already being used broadly in cybersecurity defenses.
3. A recognized subset of ML is AI.

See Appendix B for the answer.



VM LAB

You're now ready to complete the live, virtual machine labs for this module. The labs can be found each module in the MindTap.

SUMMARY

- The word “endpoint” is commonly used when referring to network-connected hardware devices. Devices that are connected to a network today include traditional desktop computers, mobile smartphones, tablets, wearable fitness trackers, and even personal drones. The word endpoint reflects the risks that have increased with using these devices. Instead of protecting devices located inside a network security perimeter, today each endpoint is a target for attackers to attempt to steal or manipulate their data. Every endpoint is a potential entry point for attackers.
- Malware (malicious software) is software that enters a computer system without the user’s knowledge or consent and then performs an unwanted and harmful action. There has been no standard established for the classification of the different types of malware so that like malware can be grouped together for study. One attempt at classifying the diverse types of malware can be to examine the primary action that the malware performs and then group those together with similar actions.
- Some types of malware attempt to take away the freedom of users to do whatever they want on their computer. These types of malware “imprison” the user. One of the fastest-growing types of malware is ransomware, which takes away users’ freedom from using their computer until the ransom is transacted. Early ransomware pretended to be from a reputable third-party, giving a “valid” reason for blocking the user’s computer. As ransomware became more widespread, the threat agents dropped the pretense that the ransomware was from a reputable third party. Instead, they simply blocked the user’s computer and demanded a fee for its release. In recent years, a more malicious form of ransomware has arisen. Instead of just blocking the user from accessing the computer, it encrypts all the files on the device so that none of them can be opened. This is called cryptomalware.
- Another category of malware infects a computer to then launch attacks on other computers. A file-based virus is remarkably similar to a biological virus. It is malicious computer code that is attached to a file. Like its biological counterpart, a file-based virus reproduces itself on the same computer. Early viruses were relatively straightforward in how they infected files. Later file-based viruses went to greater lengths to avoid detection; this type of virus is called an armored file-based virus. A fileless virus does not attach itself to a file but takes advantage of native services and processes that are part of the OS to avoid detection and carry out its attacks. These native services used in a fileless virus are called living-off-the-land binaries (LOLBins). There are several advantages of a fileless virus over a file-based virus. These include ease of infection, extensive control, persistence, difficulty in detection, and difficulty in defense. A worm is a malicious program that uses a computer network to replicate. It is designed to enter a computer through the network and then take advantage of a vulnerability in an application or an OS on the host computer. An infected computer that is under the remote control of an attacker for the purpose of launching attacks is called a bot or zombie. When large numbers of bot computers are gathered into a logical computer network, they create a botnet. Infected bot computers receive instructions through a command and control (C&C) structure.
- Another category of malware “snoops” or spies on its victims. Spyware is tracking software that is deployed without the consent or control of the user. Spyware typically secretly monitors users by collecting information without their approval using the computer’s resources, including programs already installed on the computer, to collect and distribute personal or sensitive information. A keylogger silently captures and stores each keystroke that a user types on the computer’s keyboard so that the attacker can later search the captured text for any useful information. A keylogger can be a software program or a small hardware device.
- Some malware attempts to deceive the user and hide its true intentions. A broad category of software that is often more annoying than malicious is called potentially unwanted programs (PUPs), or software that the user does not want on their computer. PUPs often become installed along with other programs when the user overlooks the default installation options on software downloads. A computer Trojan is an executable program that masquerades as performing a benign activity but also does something malicious. A special type of Trojan is a remote access Trojan (RAT). A RAT has the basic functionality of a Trojan but also gives the threat agent unauthorized remote access to the victim’s computer by using specially configured communication protocols.
- Some malware attempts to evade detection. A backdoor gives access to a computer, program, or service that circumvents any normal security protections. When installed on a computer, a backdoor allows the attacker to return later and bypass security settings. A logic bomb is computer code that is typically added to a legitimate program but lies dormant and evades detection until a specific logical event triggers it. Once it is triggered, the program then deletes data or performs other malicious activities. Logic bombs are difficult to detect before

they are triggered because they are often embedded in very large computer programs. A rootkit is malware that can hide its presence and the presence of other malware on the computer. It does this by accessing “lower layers” of the operating system or even using undocumented functions to make alterations.

- Another category of attacks specifically targets software applications that are already installed and running on the device. These attacks look for vulnerabilities in the application or manipulate the application in order to compromise it. In a cross-site scripting (XSS) attack, a website that accepts user input without validating (sanitizing) it and uses that input in a response can be exploited. Another type of attack called injections introduces new input to exploit a vulnerability. One of the most common injection attacks, called SQL injection, inserts statements to manipulate a database server. By entering crafted SQL statements as user input, information from the database can be extracted or the existing data can be manipulated. In addition to using SQL, other types of databases are used, such as those containing the eXtensible Markup Language (XML), which can also be used for data manipulation similar to an SQL injection. This is called an XML injection.
- A cross-site request forgery (CSRF) takes advantage of an authentication “token” that a website sends to a user’s web browser. If a user is currently authenticated on a website and is then tricked into loading another webpage, the new page inherits the identity and privileges of the victim, who may then perform an undesired function on the attacker’s behalf. A server-side request forgery (SSRF) takes advantage of a trusting relationship between web servers. SSRF attacks exploit how a web server processes external information received from another server. A replay attack copies data and then uses it for an attack.
- Several attacks are directed at vulnerabilities associated with how a program uses RAM. Some of these memory-related attacks are called resource exhaustion attacks because they “deplete” parts of memory and thus interfere with the normal operation of the program in RAM. This may allow the threat actor access to the underlying OS in a way that it could be exploited by bypassing security settings. A memory leak occurs when an application, instead of normally dynamically allocating memory, does not free that memory when finished using it. An attacker can then take advantage of the unexpected program behavior resulting from a low memory condition. A buffer overflow attack occurs when a process attempts to store data in RAM beyond the boundaries of a fixed-length storage buffer, and this extra data overflows into the adjacent memory locations. An attacker can overflow the buffer with a new address pointing to the attacker’s malware code. An integer overflow attack occurs when an attacker changes the value of a variable to something outside the range that the programmer had intended by using an integer overflow.
- Software that allows the user to enter data but has improper input handling features does not filter or validate user input to prevent a malicious action. Other software may not properly trap an error condition and thus provides an attacker with underlying access to the system. This is known as incorrect error handling. When an application dereferences a pointer that it expects to be valid but instead has a value of NULL, it typically will cause a program to crash or exit. A NULL pointer/object dereference can occur through a number of flaws, including simple programming omissions. It can also be the result of a race condition, in which two concurrent threads of execution access a shared resource simultaneously.
- In an application program interface (API) attack, a threat actor looks for vulnerabilities in the API, a link provided by an OS, web browser, or other platform that allows a developer access to resources at a high level. A device driver is software that controls and operates an external hardware device that is connected to a computer and is specific to both the OS and the hardware device. Threat actors may attempt to alter a device driver for use in an attack (called device driver manipulation). A dynamic link library (DLL) is a repository of both code and data that can be used by more than one program at the same time. Attackers use a technique called DLL injection for inserting code into a running process through a DLL to cause a program to function in a way other than intended.
- Artificial intelligence (AI) is technology that imitates human abilities. Although the practical use of AI has only appeared recently, it has a long history dating back to the first large-scale computers. A recognized subset of AI is machine learning (ML). ML is defined as “teaching” a technology device to “learn” by itself without the continual instructions of a computer programmer and also to learn through repeated experience. Cybersecurity AI allows organizations to detect, predict, and respond to cyberthreats in real time using ML. There are risks associated with using AI and ML in cybersecurity called adversarial artificial intelligence. One risk is the security of the ML algorithms: just as all hardware and software is subject to being infiltrated by threat actors, AI-powered cybersecurity applications and their devices likewise have vulnerabilities. Another risk is tainted training data for machine learning. Attackers can attempt to alter the training data that is used by ML in order to produce false negatives to cloak themselves.

Key Terms

adversarial artificial intelligence	fileless virus	replay
application program interface (API) attack	improper input handling	resource exhaustion attacks
backdoor	injections	rootkit
bot	integer overflow attack	security of the ML algorithms
buffer overflow attack	keylogger	server-side request forgery (SSRF)
client-side request forgery	logic bomb	shimming
command and control (C&C)	malware	spyware
cross-site request forgery (CSRF)	memory leak	SQL injection
cross-site scripting (XSS)	pointer/object dereference	Structured Query Language
cryptomalware	potentially unwanted programs (PUPs)	tainted training data for machine learning
device driver manipulation	race condition	time of check/time of use
DLL injection	ransomware	Trojan
error handling	refactoring	worm
eXtensible Markup Language (XML)	remote access Trojan	XML injection

Review Questions

- What word is the currently accepted term to refer to network-connected hardware devices?
 - Host
 - Endpoint
 - Device
 - Client
- Which of the following is NOT a characteristic of malware?
 - Deceive
 - Launch
 - Imprison
 - Diffusion
- Gabriel's sister called him about a message that suddenly appeared on her screen that says her software license has expired and she must immediately pay \$500 to have it renewed before control of the computer will be returned to her. What type of malware has infected her computer?
 - Persistent lockware
 - Blocking ransomware
 - Cryptomalware
 - Impede-ware
- Marius's team leader has just texted him that an employee, who violated company policy by bringing in a file on her USB flash drive, has just reported that her computer is suddenly locked up with cryptomalware. Why would Marius consider this a dangerous situation?
 - It sets a precedent by encouraging other employees to violate company policy.
 - Cryptomalware can encrypt all files on any network that is connected to the employee's computer.
 - The organization may be forced to pay up to \$500 for the ransom.
 - The employee would have to wait at least an hour before her computer could be restored.
- Which type of malware relies on LOLBins?
 - PUP
 - File-based virus
 - Fileless virus
 - Bot
- Which of the following is known as a network virus?
 - TAR
 - Worm
 - Remote exploitation virus (REV)
 - C&C
- Josh is researching the different types of attacks that can be generated through a botnet. Which of the following would NOT be something distributed by a botnet?
 - LOLBins
 - Spam
 - Malware
 - Ad fraud
- Which of the following is NOT a means by which a bot communicates with a C&C device?
 - Signing in to a website the bot herder operates
 - Signing in to a third-party website
 - Email
 - Command sent through Twitter posts

9. Randall's roommate is complaining to him about all of the software that came pre-installed on his new computer. He doesn't want the software because it slows down the computer. What type of software is this?
- Spyware
 - BOT
 - PUP
 - Keylogger
10. What is the difference between a Trojan and a RAT?
- There is no difference.
 - A RAT gives the attacker unauthorized remote access to the victim's computer.
 - A Trojan can carry malware while a RAT cannot.
 - A RAT can infect only a smartphone and not a computer.
11. Which of these would NOT be considered the result of a logic bomb?
- Send an email to Rowan's inbox each Monday morning with the agenda of that week's department meeting.
 - If the company's stock price drops below \$50, then credit Oscar's retirement account with one additional year of retirement credit.
 - Erase the hard drives of all the servers 90 days after Alfredo's name is removed from the list of current employees.
 - Delete all human resource records regarding Augustine one month after he leaves the company.
12. Which of the following attacks is based on a website accepting user input without sanitizing it?
- RSS
 - XSS
 - SQLS
 - SSXRS
13. Which of the following attacks is based on the principle that when a user is currently authenticated on a website and then loads another webpage, the new page inherits the identity and privileges of the first website?
- SSFR
 - DLLS
 - CSRF
 - DRCR
14. Which of the following manipulates the trusting relationship between web servers?
- SSRF
 - CSRF
 - EXMAL
 - SCSI
15. Which type of memory vulnerability attack manipulates the "return address" of the memory location of a software program?
- Shim overflow attack
 - Factor overflow attack
 - Integer overflow attack
 - Buffer overflow attack
16. What race condition can result in a NULL pointer/object dereference?
- Conflict race condition
 - Value-based race condition
 - Thread race condition
 - Time of check/time of use race condition
17. Which of the following attacks targets the external software component that is a repository of both code and data?
- Application program interface (API) attack
 - Device driver manipulation attack
 - Dynamic-link library (DLL) injection attack
 - OS REG attack
18. What term refers to changing the design of existing code?
- Library manipulation
 - Shimming
 - Refactoring
 - Design driver manipulation
19. Which of the following is technology that imitates human abilities?
- AI
 - ML
 - RC
 - XLS
20. Which statement regarding a keylogger is NOT true?
- Software keyloggers can be designed to send captured information automatically back to the attacker through the Internet.
 - Hardware keyloggers are installed between the keyboard connector and computer keyboard USB port.
 - Software keyloggers are generally easy to detect.
 - Keyloggers can be used to capture passwords, credit card numbers, or personal information.

Hands-On Projects

Project 3-1: Analyze File and URL for File-Based Viruses Using VirusTotal—Part 1

Time Required: 25 minutes

Objective: Given a scenario, analyze potential indicators to determine the type of attack.

Description: VirusTotal is a free online service that analyzes files and URLs to identify potential malware. VirusTotal combines 70 antivirus scanners and URL/domain blacklisting services along with other tools to identify malware. A wide range of files can be submitted to VirusTotal for examination, such as user data files and documents, executable programs, PDFs, and images. One of the uses of VirusTotal is to provide a “second opinion” on a file or URL that may have been flagged as suspicious by other scanning software. In this project, you use VirusTotal to scan a file and a URL.

1. First view several viruses from 20 years ago and observe their benign but annoying impact. Open your web browser and enter the URL **archive.org/details/malwaremuseum&tab=collection** (if you are no longer able to access the site through the web address, use a search engine to search for “Malware Museum”).
2. All of the viruses have been rendered ineffective and will not harm a computer. Click several of the viruses and notice what they do.
3. When finished, close your web browser.
4. Use Microsoft Word to create a document that contains the preceding paragraph description about VirusTotal. Save the document as **VirusTotal.docx**.
5. Exit Word.
6. Open your web browser and enter the URL **www.virustotal.com** (if you are no longer able to access the site through the web address, use a search engine to search for “Virus Total”).
7. If necessary, click the **File** tab.
8. Click **Choose File**.
9. Navigate to the location of **VirusTotal.docx** and click **Open**.
10. Click **Confirm upload**.
11. Wait until the upload and analysis are completed.
12. Scroll through the list of antivirus (AV) vendors that have been polled regarding this file. A green checkmark means no malware was detected.
13. Click the **DETAILS** tab and read through the analysis.
14. Use your browser’s Back button to return to the VirusTotal home page.
15. Now you will analyze a website. Click **URL**.
16. Enter the URL of your school, place of employment, or another site with which you are familiar.
17. Wait until the analysis is completed.
18. Click the **DETAILS** tab and read through the analysis.
19. Click Scroll through the list of vendor analysis. Do any of these sites indicate **Unrated site** or **Malware site**?
20. How could VirusTotal be useful to users? How could it be useful to security researchers? Could it also be used by attackers to test their own malware before distributing it to ensure that it does not trigger an AV alert? What should be the protections against this?
21. Close all windows.

Project 3-2: Analyze Virus File Using VirusTotal—Part 2

Time Required: 20 minutes

Objective: Given a scenario, analyze potential indicators to determine the type of attack.

Description: What happens when VirusTotal detects a file-based virus? In this project, you will download a file that has a “signature” of a file-based virus into a sandbox in order to upload it to VirusTotal.

NOTE 25

None of the actions in this project will harm the underlying computer.

1. Open your web browser.
2. Enter the URL **www.eicar.org/?page_id=3950**.
3. Scroll down to **Download area using the standard protocol http**.
4. Click **ecar.com** to start the download.
5. Your antimalware software on your personal computer should immediately flag this file as malicious and not allow you to download it. Because it cannot (and should not) be downloaded on your regular computer, you will instead want to use the Windows Sandbox or VMware sandbox you created in Module 1.

NOTE 26

Refer to Project 1-3 and Project 1-4 of Module 1 for creating these sandboxes.

6. If you are using the Windows Sandbox, click **Start**, scroll down to Windows Sandbox, and then click **Windows Sandbox**.
7. First you will turn off the security protections in Windows Sandbox. Click **Start** and then **Windows Security**.
8. Click the three horizontal lines at the left of the screen to display the menu options.
9. Click **App & browser control**.
10. For each of the categories, click the **Off** button to turn off security. Remember this will only impact the security within the Windows Sandbox and will have no impact on the underlying computer.
11. Open Internet Explorer in the Windows Sandbox.

NOTE 27

Be sure to use the web browser in the Windows Sandbox and not the web browser in the underlying computer.

12. Enter the URL **www.eicar.org/?page_id=3950**.
13. Scroll down to **Download area using the standard protocol http**.
14. Click **ecar.com** to start the download.
15. The antimalware software within Windows Sandbox will now allow the file to be downloaded into the Sandbox.
16. Open another tab on the Internet Explorer web browser in the Windows Sandbox, and enter the URL **www.virustotal.com** (if you are no longer able to access the site through the web address, use a search engine to search for "Virus Total").
17. If necessary, click the **File** tab.
18. Click **Choose File**.
19. Navigate to the location of **ecar.com** and click **Open**.
20. Click **Confirm upload**.
21. Wait until the upload and analysis are completed.
22. Scroll through the list of AV vendors that have been polled regarding this file. A green checkmark means no malware was detected.
23. Click the **DETAILS** tab and read through the analysis.
24. Close the Windows Sandbox. This will delete the **ecar.com** file and reset the security settings to normal.

Project 3-3: Explore Ransomware Sites

Time Required: 15 minutes

Objective: Given a scenario, analyze potential indicators to determine the type of attack.

Description: A variety of sites provide information about ransomware along with tools for counteracting some types of infection. In this project, you explore different ransomware sites.

1. Open your web browser and enter the URL **www.nomoreransom.org** (if you are not able to access this site open a search engine and search for "**Nomoreransom.org**").
2. Click the **No** button.
3. Read through the Prevention Advice. Do you think it is helpful?
4. Click **Crypto Sheriff**. How could this be useful to a user who has suffered a ransomware infection?
5. Click **Ransomware: Q&A**. Read through the information. Which statements would you agree with? Which statements would you disagree with?

6. Click **Decryption Tools**. This contains a list of different tools that may help restore a computer that has been infected by a specific type of ransomware.
7. Click one of the tools and then click **Download** to download. Note that these tools change frequently based on the latest types of ransomware that is circulating.
8. Run the program to understand how these decryption tools function. Note that you will not be able to complete the process because there are no encrypted files on the computer. Close the program.
9. Now visit another site that provides ransomware information and tools. Open your web browser and enter the URL **id-ransomware.malwarehunterteam.com**.
10. What features does this site provide?
11. How could these sites be useful?
12. Close all windows.

Project 3-4: Use a Software Keylogger



CAUTION

The purpose of this activity is to provide information regarding how these programs function in order that adequate defenses can be designed and implemented. These programs should never be used in a malicious fashion against another user.

Time Required: 25 minutes

Objective: Given a scenario, analyze potential indicators to determine the type of attack.

Description: A keylogger program captures everything that a user enters on a computer keyboard. In this project, you download and use a software keylogger.

1. Open your web browser and enter the URL **refog.com** (if you are no longer able to access the program through the URL, use a search engine to search for "Refog Keylogger").
2. Click **Features** to see the features of the product.
3. Click **Home**.
4. Click **Download**.
5. Click **Create an account** and enter the requested information.
6. Click **Download**.
7. When the file finishes downloading, run the installation program. Note that you may have to enter the password on the previous page to extract the files.
8. When prompted with **I'm going to use this software to monitor**: select **My own computer**.
9. Click **Hide program icon from Windows tray**. Click **Next**.
10. Click **I Agree**.
11. Click **Select All** and then **Next**.
12. Create a login and password for the online dashboard. Click **Activate**.
13. You will receive a message that the subscription has expired. Click **Yes** to install in offline mode.
14. Click **Install**.
15. Click **Restart Now**.
16. After the computer has restarted, use the keystroke combination **Ctrl + Alt + Shift + K** to launch Refog Keylogger.
17. Click **Tools** and then click **Settings**.
18. Note the default settings regarding what is captured.
19. Click **Back to log**.
20. Minimize Refog Keylogger.
21. Use your computer normally by opening a web browser to surf to a website. Open Microsoft Word and type several sentences. Open and close several programs on the computer.
22. Maximize Keylogger and note the information that was captured.
23. In the left pane, click through the different items that were captured.
24. Under Settings, click **Websites Visited**.
25. Under Websites Visited, click **Make website screenshots**.
26. Click **Apply**.

27. Open a web browser and surf to multiple websites.
28. Under Users, click **Websites visited**. Note the screen captures of the different sites.
29. What type of information would a software keylogger provide to a threat actor? How could it be used against the victim?
30. Click **File** and then **Exit** to close Keylogger.
31. You may uninstall Keylogger if you wish.
32. Close all windows.

Case Projects

Case Project 3-1: Biological and File-Based Viruses

The word virus comes from Latin, meaning a slimy liquid, poison, or poisonous secretion. In late Middle English, it was used for the venom of a snake. The word later evolved from the discharge to the substances within the body that caused the infectious diseases that produced the discharge. In 1799, Edward Jenner published his discovery that the cowpox virus could actually be used as a vaccine against smallpox. As biological science continued to advance, the word “virus” became even more specific when referring to tiny infectious agents—even smaller than bacteria—that replicate in living cells. This new field of virology exploded in the 1930s, when electronic microscopes allowed scientists to see viruses for the first time. Since then, scientists have continued to identify and name new biological viruses. Combating viruses by developing vaccines has many parallels to how malicious file-based viruses are identified and removed from a computer. Using the Internet, research these two types of viruses and find the similarities between combating biological and computer viruses. Write a one-to-two-paragraph summary of your research.

Case Project 3-2: Living-off-the-Land Binaries (LOLBins)

Fileless viruses take advantage of native services and processes that are part of the OS to avoid detection and carry out their attacks. These native services used in a fileless virus are called living-off-the-land binaries (LOLBins). Use the Internet to research fileless viruses and LOLBins. When did fileless viruses first appear? How do they compare with file-based viruses? What are the defenses against fileless viruses? Write a one-page paper on your research.

Case Project 3-3: Infamous Logic Bombs

Search the Internet for examples of logic bombs. Select four logic bombs and write a report about them. Who was responsible? When did the bombs go off? What was the damage? What was the penalty for the person responsible? Did the organization make any changes after the attack? How can they be prevented?

Case Project 3-4: Cybersecurity AI

The use of AI in cybersecurity is growing rapidly. Use the Internet to research the latest developments in cybersecurity AI. How does it work? What platforms are using it? What are some examples of it? How is it being improved? How can adversarial AI attacks be defended against? Write a one-page paper of what you have learned.

Case Project 3-5: Information Security Community Site Activity

The Information Security Community Site is an online companion to this textbook. It contains a wide variety of tools, information, discussion boards, and other features to assist learners. In order to gain the most benefit from the site, you will need to set up a free account.

Go to **community.cengage.com/infosec2**. Search the blogs on the topic “Ransomware.” What did you learn? What were your biggest surprises? What did you already know? How could you use this information in your first security job?

Case Project 3-6: North Ridge Security

North Ridge Security provides security consulting and assurance services. You have recently been hired as an intern to assist them.

North Ridge is preparing a presentation to the monthly meeting of IT programmers and has asked you to do research on attacks on software.

1. Create a PowerPoint presentation on memory leaks, buffer overflow, integer overflow, pointer/object dereference, and attacks using API, device drivers, and DLLs. Your presentation should be at least nine slides in length.
2. As a follow-up to your presentation, you have been asked to write a one-page report on race conditions. Use the Internet to research race conditions and how they can best be addressed.

References

1. "The state of ransomware in the US: Report and statistics 2019," *Emisoft*, Dec. 12, 2019, accessed May 6, 2020, <https://blog.emsisoft.com/en/34822/the-state-of-ransomware-in-the-us-report-and-statistics-2019/>.
2. Dudley, Renee, "The extortion economy: How insurance companies are fueling a rise in ransomware attacks," *ProPublica*, Aug. 27, 2019, accessed Oct. 27, 2019, www.propublica.org/article/the-extortion-economy-how-insurance-companies-are-fueling-a-rise-in-ransomware-attacks.
3. "Definition of computer contaminant," *Law Insider*, accessed May 9, 2020, www.lawinsider.com/dictionary/computer-contaminant.
4. "McAfee Labs Threats Report," Dec. 2018, accessed Apr. 21, 2019, www.mcafee.com/enterprise/en-us/assets/reports/rp-quarterly-threats-dec-2018.pdf.
5. "Ransomware payments up 33% as Maze and Sodinokibi proliferate in Q1 2020," *Coveware*, accessed May 5, 2020, www.coveware.com/blog/q1-2020-ransomware-marketplace-report.
6. Soare, Bianca, "This year in ransomware payouts (2019 edition)," *Heimdall Security*, Dec. 11, 2019, accessed May 9, 2020, <https://heimdalsecurity.com/blog/ransomware-payouts/>.
7. "Ransomware attacks map," *Statescoop*, accessed May 9, 2020, <https://statescoop.com/ransomware-map/>.
8. "High-impact ransomware attacks threaten U.S. businesses and organizations," *Public Service Announcement Federal Bureau of Investigation*, Oct 2, 2019, accessed May 9, 2020, www.ic3.gov/media/2019/191002.aspx.
9. "Ransomware payments up 33% as Maze and Sodinokibi proliferate in Q1 2020," *Coveware*, accessed May 5, 2020, www.coveware.com/blog/q1-2020-ransomware-marketplace-report.
10. Zumerle, Dioisio, D'Hoinne, Jeremy, and O'Neill, Mark, "How to build an effective API security strategy," *Gartner Research*, Dec. 8, 2017, accessed May 12, 2020, www.gartner.com/en/documents/3834704.
11. "Reinventing cybersecurity with artificial intelligence: The new frontier in digital security," *Capgemini Research Institute*, accessed May 13, 2020, www.capgemini.com/wp-content/uploads/2019/07/AI-in-Cybersecurity_Report_20190711_V06.pdf.

ENDPOINT AND APPLICATION DEVELOPMENT SECURITY

After completing this module, you should be able to do the following:

- 1 Describe different threat intelligence sources
- 2 List the steps for securing an endpoint
- 3 Explain how to create and deploy SecDevOps

Front-Page Cybersecurity

Suppose you were to uncover a zero-day vulnerability that nobody else knew about. What could you do with it?

You could be a broker and sell your knowledge of the vulnerability to a willing buyer. Governments often serve as buyers of zero-day vulnerabilities to protect their citizens or attack their enemies. Other willing buyers are third-party “acquisition platforms” who buy and then resell the vulnerability information to a government or a software developer. Very willing buyers are also threat actors who would craft their own attacks based on the vulnerability.

However, a more responsible option would be for you to privately disclose the vulnerability to the developer of the software, allowing the developer to fix it before an attacker uncovers and takes advantage of it. Not all zero-day vulnerabilities are discovered by individuals. Many organizations have internal security teams who look for vulnerabilities in their own code and in programs from other developers. When they find a problem, they privately contact the software developer with the information so the developer can patch it.

What happens if developers drag their feet and do not patch the vulnerability within a reasonable period of time? Delaying can keep the door open for a threat actor to find the zero-day vulnerability and exploit it.

Faced with the conundrum of trying to give developers time to create a patch and the public’s right to protection from attacks, organizations have come up with “disclosure deadlines,” or the time that the software developer is given to patch a vulnerability before it is publicly disclosed. These disclosure deadlines generally range from 45 days to 120 days.

Google started Project Zero in 2014 to look for zero-day vulnerabilities in its code and code from other software developers. Many developers responded quickly to a private alert of a zero-day vulnerability. As soon as the patch was available, Project Zero released information about it. However, not all developers moved quickly: in some instances, it took six months for the software developers to issue a patch.

Google’s Project Zero set a disclosure deadline of 90 days, after which it would go public with information about the vulnerability. Going public would alert the user base to be aware of the vulnerability and possibly stop using the software while shaming the developer into a faster response. The next year, Project Zero added a 14-day grace period: after the 90-day deadline, a developer could request two additional weeks to make a patch available. Beyond 14 days, however, Google would

go public with the information. Project Zero said that by 2019, 97.7 percent of vulnerabilities uncovered were fixed within 90 days.

However, in early 2020, Project Zero announced a trial tweak to their disclosure deadline. The limit is still 90 days. But Project Zero sometimes found that software developers were rushing to fix the zero-day vulnerability to meet the 90-day deadline, and this sometimes resulted in a rushed and flawed patch that introduced another vulnerability into the code. With Project Zero's new trial tweak, software developers will now have the full 90 days to create a patch for the vulnerability, and Project Zero will say nothing until the end of the 90 days. Even if the developer can fix the vulnerability in just 20 days, Google will still say nothing until 90 days have elapsed. However, the developer and Google can make a mutual disclosure before the 90-day deadline if both sides agree on the early disclosure.

Why the change? Project Zero says that faster patch development, while still important, is not the exclusive goal anymore. Instead, thorough patch development—not sticking a bandage on it but actually finding the underlying problem and correcting it—and improved patch adoption are also important. In the words of Project Zero, “End user security doesn't improve when a bug is found, and it doesn't improve when a bug is fixed. It improves once the end user is aware of the bug and typically patches their device.”

Attacks using malware, application attacks, and adversarial artificial intelligence attacks against endpoints continue around the clock every day. What defenses can be used to ward off these attacks?

First, it is important to access threat intelligence sources in order to be aware of the latest types of attacks and how to defend against them. With that information at hand, securing devices through boot integrity, protecting endpoints, and hardening endpoints can then effectively be used. But deploying these defenses is still considered “after the fact.” A growing chorus of security professionals today are demanding that it is the responsibility of the software developers to create and deploy software using secure application development coding techniques.

In this module, you will learn about securing endpoint devices and creating and deploying secure applications. But first you will explore the sources of threat intelligence information.

THREAT INTELLIGENCE SOURCES

CERTIFICATION

1.5 Explain different threat actors, vectors, and intelligence sources.

At one time, organizations were reluctant to share information about attacks on their networks and endpoints, often because they were concerned about “bad publicity” that might arise from this disclosure. Today that is no longer the case. Organizations are pooling their experiences and knowledge gained about the latest attacks with the broader security community. Sharing this type of information has become an important aid to help other organizations shore up their defenses.

One type of shared information is the evidence of an attack. Most organizations monitor their networking environment to determine what normally occurs. They use this data to create a database of *key risk indicators (KRIs)*. A KRI is a metric of the upper and lower bounds of specific indicators of normal network activity. These indicators may include the total network logs per second, number of failed remote logins, network bandwidth, and outbound email traffic. A KRI exceeding its normal bounds could be (but is not always) an **indicator of compromise (IOC)**. An IOC shows that a malicious activity is occurring but is still in the early stages of an attack.

Making IOC information available to others can prove to be of high value as it may indicate a common attack that other organizations are also experiencing or will soon experience. This information aids others in their **predictive analysis** or discovering an attack before it occurs.

NOTE 1

Like radar that shows the enemy approaching, predictive analysis helps determine when and where attacks may occur.

Threat intelligence sources fall into several categories, as do the sources from which threat intelligence information can be gathered.

Categories of Sources

The two categories of threat intelligence sources are open source and closed source.

Open Source Information

The phrase **open source** has its roots in the computer industry. Initially, it referred to software for which the *source code* was open for anyone to examine. Over time, “open source” was used to refer to anything that could be freely used without restrictions, such as an *open source film* or *open source curriculum*.

NOTE 2

The phrase “open source” came out of a strategy session in 1998 by about a half dozen Linux software developers who wanted to take advantage of an announcement by Netscape that it was planning to give away the source code of its browser. The developers wanted to persuade the corporate world about the superiority of an open software development process but found that the phrase “free software” that had been used previously carried a stigma of being inferior. After a brainstorming session, the label “open source” was agreed upon.

Open source threat intelligence information that is freely available, often called open source intelligence (OSINT), has become a vital resource. This information is often collected and then disseminated through **public information sharing centers**. A typical sharing center is the U.S. Department of Homeland Security (DHS) Cyber Information Sharing and Collaboration Program (CISCP). The CISCP “enables actionable, relevant, and timely unclassified information exchange through trusted public-private partnerships across all critical infrastructure sectors.” With the DHS serving as the coordinator, the CISCP enables its members (called “partners”) to not only share threat and vulnerability information but also take advantage of the DHS’s cyber resources. Some of the CISCP services include the following:

- *Analyst-to-analyst technical exchanges*. Partners can share and receive information on threat actor tactics, techniques, and procedures (TTPs) and emerging trends.
- *CISCP analytical products*. A portal can be accessed through which partners can receive analysis of products and threats.
- *Cross industry orchestration*. Partners can share lessons learned and their expertise with peers across common sectors.
- *Digital malware analysis*. Suspected malware can be submitted to be analyzed and then used to generate malware analysis reports to mitigate threats and attack vectors.

The two concerns around public information sharing centers are the privacy of shared information and the speed at which the information is shared.

Privacy A concern about using public information sharing centers is that of privacy. An organization that is the victim of an attack must be careful not to share proprietary or sensitive information when providing IOCs and attack details.

As a safeguard, most public information sharing centers have protections in place to prevent the disclosure of proprietary information. For example, Table 4-1 lists the privacy protections of the CISCP.

Speed Threat intelligence information must be distributed as quickly as possible to others. To rely on email alerts that require a human to read them and then react takes far too much time. As an alternative, **Automated Indicator Sharing (AIS)** can be used instead. AIS enables the exchange of cyberthreat indicators between parties through computer-to-computer communication, not email communication. Threat indicators such as malicious IP addresses or the sender address of a phishing email can be quickly distributed to enable others to repel these attacks.

NOTE 3

The CISCP program is free to join and use. Those interested must agree to a Cyber Information Sharing and Collaboration Agreement (CISCA), which enables DHS and its partners to exchange anonymized information. Once partners sign the agreement, DHS coordinates an on-boarding session to customize how DHS and the organization can exchange information.

NOTE 4

Those participating in AIS generally are connected to a managed system controlled by the public information sharing center that allows bidirectional sharing of cyberthreat indicators. Not only do participants receive indicators, but they can also share indicators they have observed in their own network defenses to the public center, which then distributes them to all participants.

Table 4-1 CISCIP privacy protections

Protection	Explanation	Example
Cybersecurity Information Sharing Act (CISA)	CISA is a federal law passed in 2015 that provides authority for cybersecurity information sharing between the private sector, state, and local governments and the federal government.	CISA requires a non-federal entity to remove any information from a cyberthreat indicator that it knows at the time of sharing to be personal information of a specific individual or information that identifies a specific individual that is not directly related to a cybersecurity threat.
Freedom of Information Act (FOIA)	FOIA was passed in 1967 and provides the public the right to request access to records from any federal agency.	Although federal agencies are required to disclose any information requested under the FOIA, they offer nine exemptions, one of which protects interests such as personal privacy.
Traffic-Light Protocol (TLP)	TLP is a set of designations used to ensure that sensitive information is shared only with the appropriate audience.	TLP uses four colors (red, amber, green, and white) to indicate the expected sharing limitations the recipients should apply.
Protected Critical Infrastructure Information (PCII)	The PCII Act of 2002 protects private sector infrastructure information that is voluntarily shared with the government for the purposes of homeland security.	To qualify for PCII protections, information must be related to the security of the critical infrastructure, voluntarily submitted, and not submitted in place of compliance with a regulatory requirement.

NOTE 5

APIs are covered in Module 3.

Two tools facilitate AIS. **Structured Threat Information Expression (STIX)** is a language and format used to exchange cyberthreat intelligence. All information about a threat can be represented with objects and descriptive relationships. STIX information can be visually represented for a security analyst to view or stored in a lightweight format to be used by a computer. **Trusted Automated Exchange of Intelligence Information (TAXII)** is an application protocol for exchanging cyberthreat intelligence over Hypertext Transfer Protocol Secure (HTTPS). TAXII defines an *application protocol interface (API)* and a set of requirements for TAXII clients and servers.

Closed Source Information

Closed source is the opposite of open source. It is *proprietary*, meaning it is owned by an entity that has an exclusive right to it. Organizations that are participants in closed source information are part of **private information sharing centers** that restrict both access to data and participation. Whereas private sharing centers are similar to public sharing centers in that members share threat intelligence information, insights, and best practices, private sharing centers are restrictive regarding who may participate. All candidates must go through a vetting process and meet certain criteria.

NOTE 6

AIS is used more extensively with public information sharing centers than private centers.

Sources of Threat Intelligence

Several sources of threat intelligence are useful. These include the following:

- **Vulnerability databases.** A **vulnerability database** is a repository of known vulnerabilities and information as to how they have been exploited. These databases create “feeds” of the latest cybersecurity incidences. Common cybersecurity data feeds include *vulnerability feeds* that provide information on the latest vulnerabilities and *threat feeds* that outline current threats and attacks. The *adversary tactics, techniques, and procedures (TTP)* is a database of the behavior of threat actors and how they orchestrate and manage attacks.
- **Threat maps.** A cybersecurity **threat map** illustrates cyberthreats overlaid on a diagrammatic representation of a geographical area. Figure 4-1 illustrates a threat map. Threat maps help in visualizing attacks and provide a limited amount of context of the source and the target countries, the attack types, and historical and near real-time data about threats.

NOTE 7

Data feeds, vulnerability feeds, threat feeds, and TTP are covered in Module 2.



Figure 4-1 Threat map

CAUTION

Threat maps may look impressive, but in reality, they provide limited valuable information. Many maps claim that they show data in real time, but most are simply a playback of previous attacks. Because threat maps show anonymized data, it is impossible to know the identity of the attackers or the victims. Also, threat actors usually mask their real locations, so what is displayed on a threat map is incorrect. As a result, many cybersecurity professionals question the value of threat maps.

- **File and code repositories.** **File and code repositories** are another source of threat intelligence. Victims of an attack can upload malicious files and software code that can then be examined by others to learn more about the attacks and craft their defenses. Several entities of the U.S. government—including the Federal Bureau of Investigation (FBI), the Cybersecurity and Infrastructure Security Agency (CISA), and the Department of Defense (DoD) U.S. Cyber Command—are particularly active in posting to file and code repositories. Often samples of recently discovered malware variants are uploaded to the VirusTotal malware aggregation repository along with published detailed malware analysis reports (MARS) containing IOCs for each malware variant.

NOTE 8

The Hands-On Projects 3-1 and 3-2 in Module 3 provide you with experience using VirusTotal.

- **Dark web.** The web has three levels, as illustrated in Figure 4-2: the *clear web*, which includes ordinary websites (social media, ecommerce, news, etc.) that most users access regularly and can be located by a search engine; the *deep web*, which includes exclusive and protected websites (corporate email, material behind a digital paywall, cloud hosting services, etc.) that are hidden from a search engine and cannot be accessed without valid credentials; and the **dark web**. The dark web is like the deep web in that it is beyond the reach of a normal search engine, but it is the domain of threat actors. Using special software such as *Tor* or *I2P* (*Invisible Internet Project*) this software will mask the user's identity to allow for malicious activity such as selling drugs and stolen personal information and buying and selling malicious software used for attacks. Some security professionals and organizations use the dark web on a limited basis to look for signs that information critical to that enterprise is being sought out or sold on the dark web.



Figure 4-2 Dark web

! CAUTION

Finding information on the dark web is difficult. First, it requires using Tor or IP2, which prevents a device's IP address being traced. Second, although some dark web search engines are available, they are unlike regular search engines such as Google. The dark web search engines are difficult to use and notoriously inaccurate. One reason is because merchants who buy and sell stolen data or illicit drugs are constantly on the run, and their dark websites appear and then suddenly disappear with no warning. Finally, dark websites use a naming structure that results in URLs such as *p6f47s5p3dq3qkd.onion*. All of these are hurdles that keep out anyone who does not understand these inner workings.

TWO RIGHTS & A WRONG

1. Two concerns about public information sharing centers are the privacy of shared information and the speed at which the information is shared.
2. Two tools that facilitate AIS are STIX and TAXII.
3. Security professionals consider threat maps a vital source of information.

See Appendix B for the answer.

SECURING ENDPOINT COMPUTERS

CERTIFICATION

3.2 Given a scenario, implement host or application security solutions.

4.4 Given an incident, apply mitigation techniques or controls to secure an environment.

Despite the fact that endpoint devices like smartphones, tablets, and wearable fitness trackers receive the bulk of attention today, the “workhorse” of technology remains the personal computer. More than 260 million computers are sold annually in the United States¹ compared to 160 million smartphones sold each year.² While all endpoints must be protected from attacks, endpoint desktop and laptop computers must be secured because they are connected to corporate networks and its data, they contain data stored locally, and they can be used as a springboard to attack other endpoints.

Securing endpoint computers primarily involves three major tasks: *confirming* that the computer has started securely, *protecting* the computer from attacks, and then *hardening* it for even greater protection.

Confirm Boot Integrity

One of the steps that is often overlooked in securing endpoint computers is to confirm that the computer has started without any malicious activity taking place. Ensuring secure startup involves the Unified Extensible Firmware Interface (UEFI) and its boot security features.

Unified Extensible Firmware Interface (UEFI)

Early cowboys and workhands were known for wearing tall, tight-fitting boots. These boots had a tab or loop at the top through which a tool called a boot hook could be inserted to assist in pulling on the boot. In the mid-1800s, the expression *pull yourself up by your own bootstraps* was used to describe an impossible task of lifting oneself off the ground by pulling on the bootstrap. The phrase later came to mean to improve your situation by your own efforts without any external help.

Computers adopted this language to describe the process of starting a computer when it has been powered off. Because a computer is unable to rely on external assistance when powered on, starting a computer is called *booting up* or just *booting*.

The booting process on early personal computers, both Apple Mac and Windows PC, used firmware called the *BIOS (Basic Input/Output System)*. The BIOS was a chip integrated into the computer’s motherboard. When the computer was powered on, the BIOS software would “awaken” and perform the following steps in a *legacy BIOS boot*:

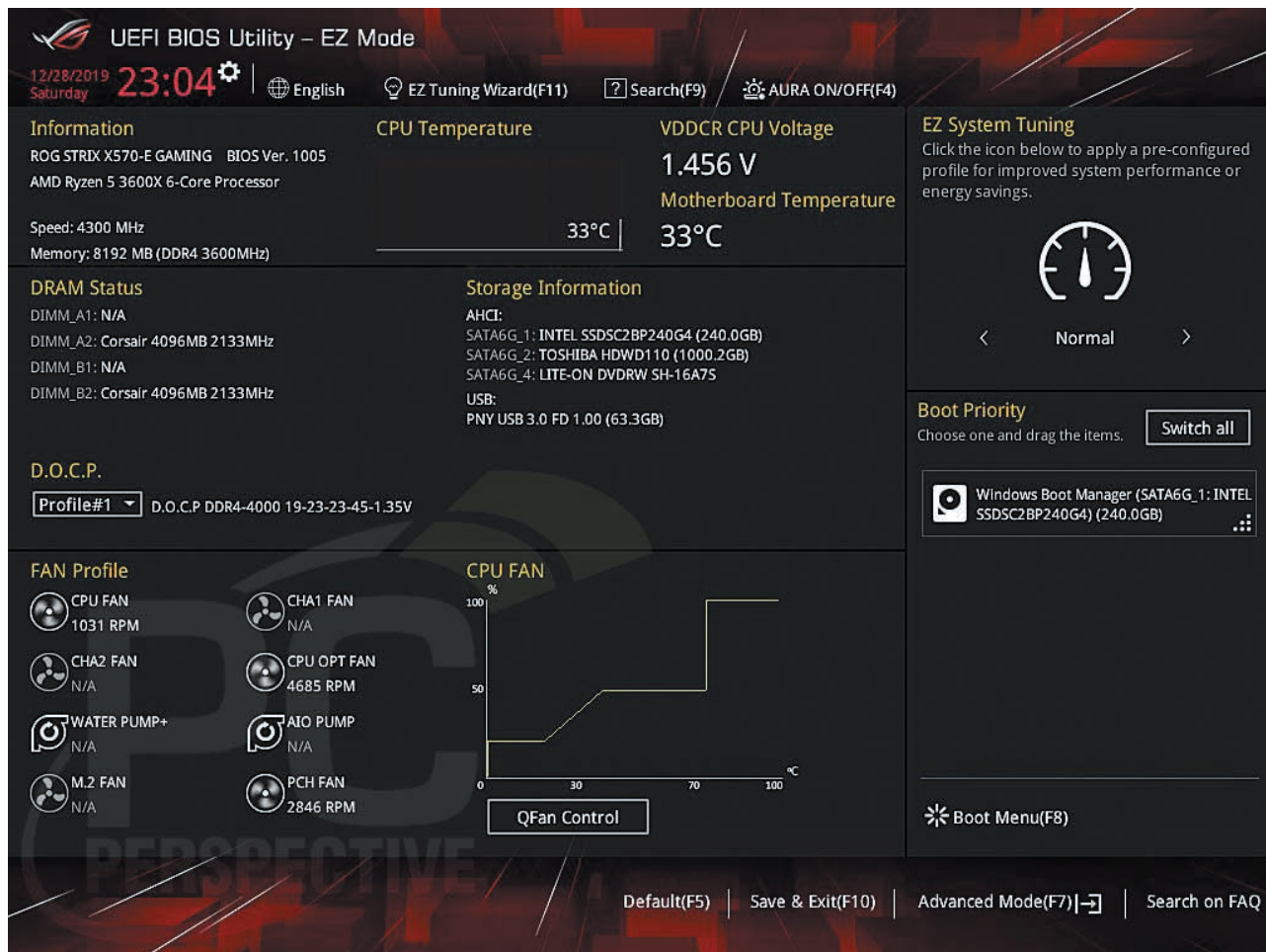
1. The BIOS would first test the various components of the computer to ensure that they were functioning properly (called the *POST* or *Power-On Self-Test*).
2. Next, the BIOS would reference the *Master Boot Record (MBR)* that specified the computer’s *partition table*, which instructed the BIOS where the computer’s operating system (OS) could be located.
3. Finally, the BIOS passed control to the installed boot loader, which launched the OS.

Originally, BIOS firmware was stored in a *ROM (read-only memory)* chip on the motherboard, supplemented by a *CMOS (complementary metal-oxide-semiconductor)* chip that stored any changes to the BIOS. Later computer systems stored the BIOS contents in *flash memory* so it could be easily updated. This provided the ability to update to the BIOS firmware so new features could be added.

NOTE 9

Although BIOS chips were nonvolatile (they retained the information even when the computer was turned off), CMOS needed its own dedicated power source, which was a lithium-ion battery about the size of a coin that could hold a charge for up to 10 years before needing to be replaced. If the CMOS battery died, the BIOS settings were not lost but instead were reset to their default settings.

To add functionality, an improved firmware interface was developed to replace the BIOS. Known as **UEFI (Unified Extensible Firmware Interface)**, it provides several enhancements over BIOS. This includes the ability to access hard drives that are larger than two terabytes (TB), support for an unlimited number of primary hard drive partitions, faster booting, and support for networking functionality in the UEFI firmware itself to aid in remote troubleshooting. UEFI also has a more advanced user interface for configurations and information, as seen in Figure 4-3.



Source: ASUS

Figure 4-3 UEFI user interface

NOTE 10

Legacy BIOS boot support from motherboard manufacturers ended in 2020 and UEFI is now the standard.

Boot Security

Another significant improvement of UEFI over BIOS relates to boot security. The ability to update the BIOS in firmware also opened the door for a threat actor to create malware to infect the BIOS. Called a *BIOS attack*, it would exploit the update feature of the BIOS. Because the BIOS resides in firmware and an infected BIOS would then persistently re-infect the computer whenever it was powered on, BIOS attacks were difficult to uncover and hard to disinfect. UEFI, used along with other components, is designed to combat these BIOS vulnerabilities and provide improved boot security.



CAUTION

UEFI by itself does not provide enhanced boot security. It must be paired with other boot security functions.

Boot security involves validating that each element used in each step of the boot process has not been modified. This process begins with the validation of the first element (boot software). Once the first element has been validated, it can then validate the next item (such as software drivers) and so on until control has been handed over to the OS.

This is called a *chain of trust*: each element relies on the confirmation of the previous element to know that the entire process is secure.

But how does the chain begin? What if a threat actor were to inject malware prior to start of the chain of trust? If the starting point is software, it can be replaced or modified. That would then compromise each element of the chain. To prevent this, a chain of trust requires a strong starting point.

The strongest starting point is hardware, which cannot be modified like software. This is known as the **hardware root of trust**. Security checks are “rooted” in (begin with) hardware checks. Because this chain of trust begins with a hardware verification, each subsequent check can rely upon it (called **boot attestation**).

Several techniques can be used to assure boot security, all of which rely on UEFI; some also rely on the hardware root of trust. Boot security modes are listed in Table 4-2.

Table 4-2 Boot security modes

Name	Description	Advantages	Disadvantages
Legacy BIOS Boot	Uses BIOS for boot functions	Compatible with older systems	No security features
UEFI Native Mode	Uses UEFI standards for boot functions	Security boot modules can be patched or updated as needed.	No validation or protection of the boot process
Secure Boot	Each firmware and software executable at boot time must be verified as having prior approval.	All system firmware, bootloaders, kernels, and other boot-time executables are validated.	Custom hardware, firmware, and software may not pass without first being submitted to system vendors like Microsoft.
Trusted Boot	Windows OS checks the integrity of every component of boot process before loading it.	Takes over where Secure Boot leaves off by validating the Windows 10 software before loading it	Requires using Microsoft OS
Measured Boot	Computer's firmware logs the boot process so the OS can send it to a trusted server to assess the security.	Provides highest degree of security	Could slow down the boot process



CAUTION

The Secure Boot security standard is designed to ensure that a computer boots using only software that is trusted by the computer manufacturer. Manufacturers can update the list of trusted hardware, drivers, and OS for a computer, which are stored in the Secure Boot database on the computer. Although it is possible for the user to disable Secure Boot to install hardware or run software or OS that have not been trusted by the manufacturer, this makes it difficult or impossible to reactivate Secure Boot without restoring the computer back to its original factory state.

Protect Endpoints

Once boot security has been established; the computer endpoints must be actively protected. The protection can be done through software installed on the endpoint, such as antivirus software, antimalware, web browser protections, and monitoring and response systems.

Antivirus

One of the first software protections was **antivirus (AV)** software. This software can examine a computer for file-based virus infections as well as monitor computer activity and scan new documents that might contain a virus. (Scanning is typically performed when files are opened, created, or closed.) If a virus is detected, options generally include cleaning the file of the virus, quarantining the infected file, or deleting the file. Log files created by AV products can also provide beneficial information regarding attacks.

NOTE 11

Viruses are covered in Module 3.

Many AV products use signature-based monitoring, also called *static analysis*. The AV software scans files by attempting to match known virus patterns against potentially infected files (called *string scanning*). Other variations include *wildcard scanning* (a wildcard is allowed to skip bytes or ranges of bytes instead of looking for an exact match) and *mismatch scanning* (mismatches allow a set number of bytes in the string to be any value regardless of their position in the string).



CAUTION

The weakness of signature-based monitoring is that the AV vendor must constantly be searching for new viruses, extracting virus signatures, and distributing those updated databases to all users. Any out-of-date signature database could result in an infection.

NOTE 12

One AV heuristic monitoring technique used is *code emulation* in which a virtual environment is created that simulates the CPU and memory of the computer. Any questionable program code is executed in the virtual environment (no actual virus code is executed by the real CPU) to determine if it is a virus.

NOTE 13

Bayesian filters generally trap a much higher percentage of spam than other techniques.

ranking. A word such as “report” may occur frequently in nonspam messages and would receive a 99 percent probability of being a nonspam word, while a word like “sex” may receive a 99 percent probability of being a spam word. Whenever email arrives, the filter looks for the 15 words with the highest probabilities to calculate the message’s overall spam probability rating.

NOTE 14

A pop-up blocker can be part of an antimalware package, a separate program, or a feature incorporated within a browser that stops pop-up advertisements from appearing.

A newer approach to AV is heuristic monitoring (called *dynamic analysis*), which uses a variety of techniques to spot the characteristics of a virus instead of attempting to make matches. The difference between static analysis and dynamic analysis detection is similar to how airport security personnel in some nations screen for terrorists. A known terrorist attempting to go through security can be identified by comparing his face against photographs of known terrorists (static analysis). What about a new terrorist with no photograph? Security personnel can look at the person’s characteristics—holding a one-way ticket, not checking any luggage, showing extreme nervousness—as possible indicators that the individual may need to be questioned (dynamic analysis).

Antimalware

Instead of only protecting against file-based viruses as with AV, **antimalware** is a suite of software intended to provide protections against multiple types of malware, such as ransomware, cryptomalware, and Trojans.

Some antimalware software protects against spam that has evaded the corporate email gateway and monitors emails for spam and other unwanted content. Antimalware spam protection is often performed using a technique called *Bayesian filtering*. The software divides email messages that have been received into two piles, spam and nonspam. The filter then analyzes every word in each email and determines how frequently a word occurs in the spam pile compared to the nonspam pile. A word such as “the” would occur equally in both piles and be given a neutral 50 percent

Another component of an antimalware suite is *antispyware*, which helps prevent computers from becoming infected by spyware. One common technique is to use a *pop-up blocker*. A *pop-up* is a small web browser window that appears over a webpage. Most pop-up windows are created by advertisers and launch as soon as a new website is visited. Using a pop-up blocker, users can often select the level of blocking, ranging from blocking all pop-ups to allowing specific pop-ups.

Web Browsers

Web browsers have a degree of security that can protect endpoint computers. This security includes secure cookies and HTTP headers.

Secure Cookies The Hypertext Transfer Protocol (HTTP) is the Internet-based protocol that is the foundation of all data exchanges on the web. It is a client-server protocol so that requests are initiated by the recipient or client, usually a web browser, to a web server.

One of the limitations of HTTP is that it is a *stateless protocol*. Unlike a *stateful protocol*, which “remembers” everything that occurs between the browser client and the server, a stateless protocol “forgets” what occurs when the session is interrupted or ends. Three ways the stateless protocol HTTP can mimic a stateful protocol include the following:

- Using a URL extension so the state is sent as part of the URL as a response
- Using “hidden form fields” in which the state is sent to the client as part of the response and returned to the server as part of a form’s hidden data
- Storing user-specific information in a file on the user’s local computer and then retrieve it later in a file called a *cookie*.

Websites use several types of cookies. A *first-party cookie* is created from the website that a user is currently viewing; whenever the user returns to this site, that cookie is used by the site to view the user’s preferences and better customize the browsing experience. Some websites attempt to place additional cookies on the local hard drive. These cookies often come from third parties that advertise on the site and want to record the user’s preferences. These cookies are called *third-party cookies*. A *session cookie* is stored in random-access memory (RAM), instead of on the hard drive, and only lasts for the duration of visiting the website.

Cookies can pose security risks as well as privacy risks. First-party cookies can be stolen and used to impersonate the user, while third-party cookies can be used to track the browsing or buying habits of a user. When multiple websites are serviced by a single marketing organization, cookies can be used to track browsing habits on all the client’s sites.

As a means of protection for cookies, a web browser can send a **secure cookie**. This cookie is only sent to the server with an encrypted request over the secure HTTPS protocol. This prevents an unauthorized person from intercepting a cookie that is being transmitted between the browser and the web server.

HTTP Response Headers When users visit a website through their web browser, the web server answers back with **HTTP Response Headers**. These headers tell the browser how to behave while communicating with the website. Several HTTP Response Headers can improve security; these are listed in Table 4-3.

Table 4-3 HTTP response headers

HTTP response header	Description	Protection
HTTP Strict Transport Security (HSTS)	Forces browser to communicate over more secure HTTPS instead of HTTP	Encrypts transmissions to prevent unauthorized user from intercepting
Content Security Policy (CSP)	Restricts the resources a user is allowed to load within the website	Protects against injection attacks
Cross Site Scripting Protection (X-XSS)	Prohibits a page from loading if it detects a cross-site scripting attack	Prevents XSS attacks
X-Frame-Options	Prevents attackers from “overlying” their content on the webpage	Foils a threat actor’s attempt to trick a user into providing personal information

Monitoring and Response Systems

The three types of monitoring and response systems for endpoint computers are host intrusion detection systems (HIDS), host intrusion prevention systems (HIPS), and endpoint detection and response (EDR).

Host Intrusion Detection Systems (HIDS) A **host intrusion detection system (HIDS)** is a software-based application that runs on an endpoint computer and can detect that an attack has occurred. The primary function of a HIDS is automated detection, which saves someone from sorting through log files to find an indication of unusual behavior. HIDS can quickly detect evidence that an intrusion has occurred. Figure 4-4 shows a HIDS dashboard.

NOTE 15

A cookie can contain a variety of information based on the user’s preferences when visiting a website. For example, if a user inquires about a rental car at the car agency’s website, that site might create a cookie that contains the user’s travel itinerary. In addition, it may record the pages visited on a site to help the site customize the view for any future visits. Cookies can also store any personally identifiable information (name, email address, work address, telephone number, and so on) that was provided when visiting the site; however, a website cannot gain access to private information stored on the local computer.

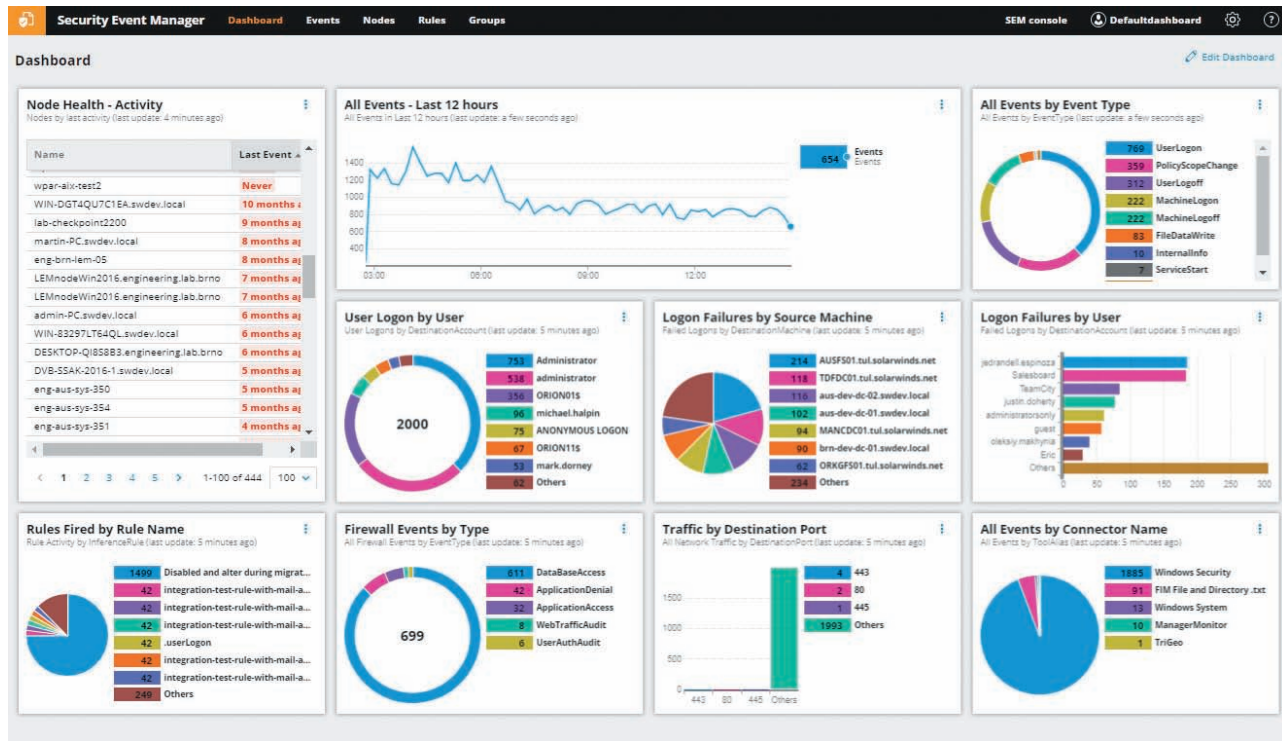


Figure 4-4 HIDS dashboard

A HIDS relies on agents installed directly on the endpoint, and these agents work closely with the OS to observe activity. HIDSs typically monitor these types of endpoint computer functions:

- **System calls.** Each operation in a computing environment starts with a *system call*. A system call is an instruction that interrupts the program being executed and requests a service from the operating system. HIDS can monitor system calls based on the process, mode, and action being requested.
- **File system access.** System calls usually require specific files to be opened to access data. A HIDS works to ensure that all file openings are based on legitimate needs and are not the result of malicious activity.
- **Host input/output.** HIDS monitors all input and output communications to watch for malicious activity. For example, if the system never uses instant messaging (IM) and suddenly a threat attempts to open an IM connection from the system, the HIDS would detect this as anomalous activity.

Host Intrusion Prevention Systems (HIPS) As its name implies, an intrusion *prevention* system not only monitors to detect malicious activities but also attempts to stop them. A **host intrusion prevention system (HIPS)** monitors endpoint activity to immediately block a malicious attack by following specific rules. Activity that a HIPS watches for includes an event that attempts to control other programs, terminate programs, and install devices and drivers. When a HIPS blocks action, it then alerts the user so an appropriate decision about what to do can be made.

CAUTION

One of the drawbacks to a HIPS is a high number of false positives can be generated. Both legitimate and malicious programs often access the same resource, and each can cause a HIPS to then block the action.

Endpoint Detection and Response (EDR) **Endpoint detection and response (EDR)** tools have a similar functionality to HIDS of monitoring endpoint events and of HIPS of taking immediate action. However, EDR tools are considered more robust than HIDS and HIPS. First, an EDR can aggregate data from multiple endpoint computers to a centralized database so that security professionals can further investigate and gain a better picture of events occurring across multiple endpoints instead of just on a single endpoint. This can help determine if an attack is more widespread across the enterprise and if more comprehensive and higher-level action needs to be taken. Second, EDR tools can perform

more sophisticated analytics that identify patterns and detect anomalies. This can help detect unusual or unrecognized activities by performing baseline comparisons of normal behavior.

Harden Endpoints

After boot security has been established and the endpoints have been protected, the next step is to harden the endpoints for further protection. Hardening endpoints involves patch management and OS protections.

Patch Management

One of the most important steps in securing an endpoint computer is to promptly install patches. Threat actors often watch for the release of a patch and then immediately craft an attack around the vulnerability the patch addresses, knowing that many users and organizations are lax in applying patches.

Effective patch management involves two types of patch management tools to administer patches. The first type includes tools for patch distribution, while the second type involves patch reception.

Patch Distribution Modern operating systems—such as Red Hat Linux, Apple macOS, Ubuntu Linux, and Microsoft Windows—frequently distribute patches. A growing number of application and utility software developers are also distributing patches for their products (**third-party updates**).

These patches, however, can sometimes create new problems, such as preventing a custom application from running correctly. Organizations that have these types of applications usually test patches when they are released to ensure that they do not adversely affect any customized applications. In these instances, the organization delays the installation of a patch from the vendor's online update service until the patch is thoroughly tested. But how can an organization prevent its employees from installing the latest patch until it has passed testing and still ensure that all users download and install necessary patches?

The answer is an *automated patch update service*. This service is used to manage patches within the enterprise instead of relying upon the vendor's online update service. An automated patch update service typically consists of a component installed on one or more servers inside the corporate network. Because these servers can replicate information among themselves, usually only one of the servers must be connected to the vendor's online update service, as seen in Figure 4-5.

Advantages of using an automated patch update service include the following:

- Downloading patches from a local server instead of using the vendor's online update service can save bandwidth and time because each computer does not have to connect to an external server.
- Administrators can approve or decline updates for client systems, force updates to install by a specific date, and obtain reports on what updates each computer needs.
- Administrators can approve updates for “detection” only; this allows them to see which computers require the update without installing it.

Patch Reception Early versions of OSs allowed the user to configure how they receive patches. For example, prior to Windows 10, Microsoft users had several options regarding accepting or even rejecting patches. These options included *Install updates automatically*, *Download updates but let me choose whether to install them*, *Check for updates but let me choose whether to download and install them*, and *Never check for updates*. However, this approach frequently resulted in important security patches being ignored by users and putting their computers at risk.

Today users have fewer—if *any*—options regarding patches: usually patches are automatically downloaded and installed whenever they become available. This is called **auto-update**, and it ensures that the software is always up to date.

Microsoft Windows 10 is typical of the enhancements of patch reception. Figure 4-6 shows the Windows 10 Advanced options. These options include the following:

- **Forced updates.** Users can no longer refuse or indefinitely delay security updates. By default, all updates will be downloaded and installed automatically. However, users can defer the “quality updates” (those with security patches) but only for seven days (Windows 10 Home edition) or 35 days (all other versions). New feature updates (those without security patches) can be delayed for 35 days (Windows 10 Home edition) or 365 days (all other versions).

NOTE 16

Many EDRs also allow for a manual or user analysis of the data.

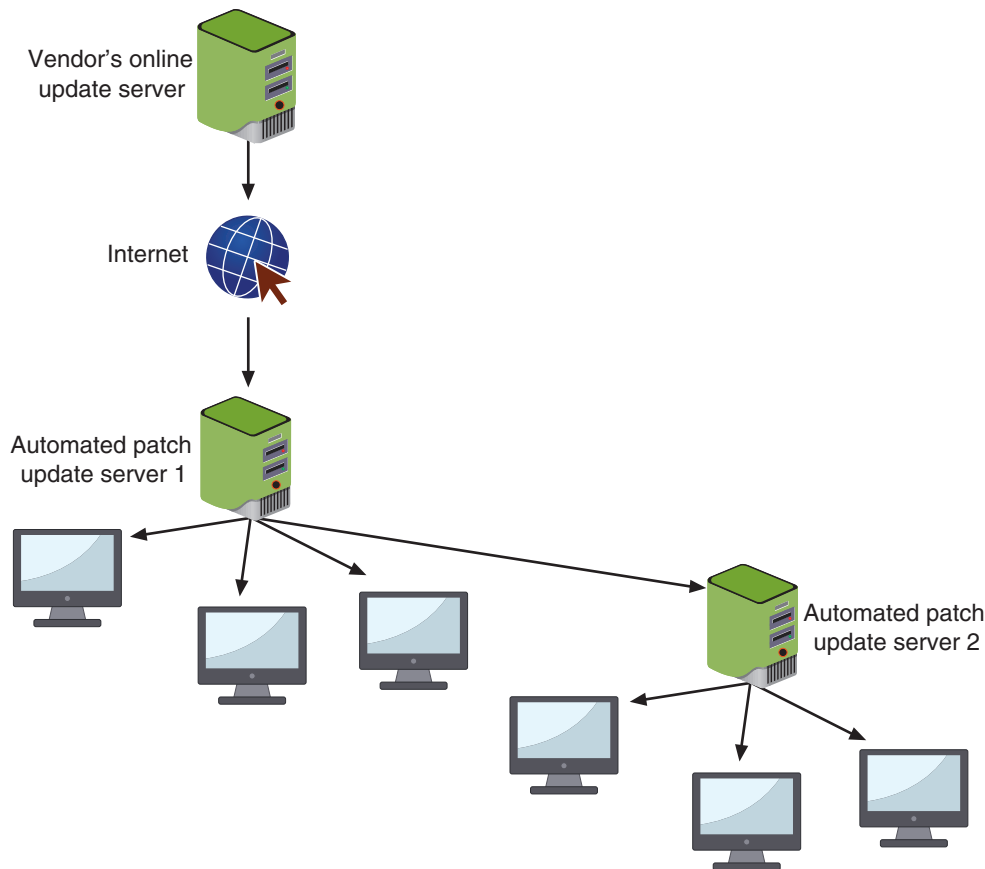


Figure 4-5 Automated patch update service

- *No selective updates.* Unlike in previous versions of Windows, users cannot select individual Windows updates to download and install. However, users can select if they want to receive updates for other installed Microsoft products (such as Office).
- *More efficient distribution.* If many Windows 10 devices are connected to a network, each device does not have to download the updates over the Internet individually. Instead, once one device has downloaded the updates, they can then be distributed to the other devices across the local network. In addition, Windows will not download updates on mobile devices unless that device is connected to an unrestricted Wi-Fi network (so that it does not use the cellular data connections that users pay for).

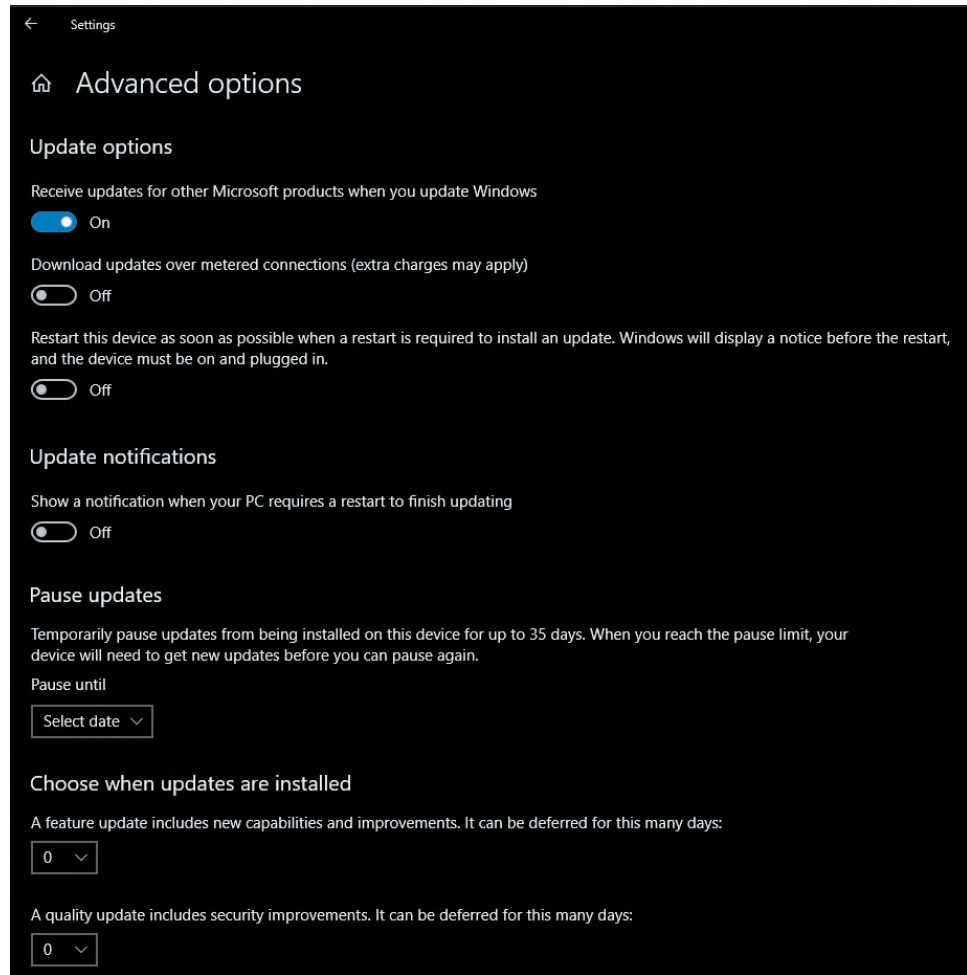
Operating Systems

There are different types and uses of operating systems. Several of the major types are listed in Table 4-4.

Although protections within the OS are designed to provide security for the endpoint device, the OS itself must be protected. Securing an OS involves proper security configurations and using confinement tools.

Security Configuration The security of an OS depends upon the proper configuration of its built-in security features. Modern operating systems have hundreds of security settings. A typical OS security configuration should include the following:

- *Disabling unnecessary ports and services.* One of the primary OS security configurations involves **disabling unnecessary open ports and services**, or “turning off” any service that is not being used, such as Microsoft Windows ASP.NET State Service, Portable Device Enumerator Service, and Apple macOS Spotlight Indexing. In addition, closing any unnecessary TCP ports can also enhance security.
- *Disabling default accounts/passwords.* Another important disabling function is disabling default accounts and passwords. Some OSs include unnecessary accounts. For example, Microsoft Windows 10 includes a *built-in Administrator account* that can be used for those building new computers to run programs and applications



Source: Used with permissions from Microsoft

Figure 4-6 Microsoft Windows 10 Advanced options

Table 4-4 Types of OSs

OS type	Uses	Examples
Network OS	Software that runs on a network device like a firewall, router, or switch	Cisco Internetwork Operating System (IOS), Juniper JUNOS, MikroTik RouterOS
Server OS	Operating system software that runs on a network server to provide resources to network users	Microsoft Windows Server, Apple macOS Server, Red Hat Linux
Workstation OS	Software that manages hardware and software on a client computer	Microsoft Windows, Apple macOS, Ubuntu Linux
Appliance OS	OS in firmware that is designed to manage a specific device like a digital video recorder or video game console.	Linpus Linux
Kiosk OS	System and user interface software for an interactive kiosk	Microsoft Windows, Google Chrome OS, Apple iOS, Instant WebKiosk, KioWare (Android)
Mobile OS	Operating system for mobile phones, smartphones, tablets, and other handheld devices	Google Android, Apple iOS, Apple iPadOS

before a user account is created. In addition, some accounts may come with default passwords that should be changed.

- *Employing least functionality.* The concept of “least functionality” states a user should only be given the minimum set of permissions required to perform necessary tasks; all other permissions should be configured as not available to the user. For example, a user should not have the ability to modify system security features.

Instead of recreating the same security configuration on each endpoint computer, tools can be used to automate the process. In Microsoft Windows, a *security template* is a collection of security configuration settings. These settings typically include account policies, user rights, event log settings, restricted groups, system services, file permissions, and registry permissions. Once a single endpoint computer has been configured properly, a security template from that device can be developed and used for deploying to other systems. Predefined security templates are also available to be imported, and these settings then can be modified to create a unique security configuration for all endpoints.

NOTE 17

Although a Microsoft Windows security template can be deployed manually, this requires an administrator to access each computer and apply the security template either through using the command line or a *snap-in*, which is a software module that provides administrative capabilities for a device. A preferred method is to use *Group Policy*, which is a feature that provides centralized management and configuration of computers and remote users who are using specific Microsoft directory services known as *Active Directory (AD)*. Group Policy allows a single configuration to be set and then deployed to many or all users.

NOTE 18

Tamper Protection also prevents changes to security settings by programs, Windows command line commands, or through Group Policy.

NOTE 19

Instead of managing security options on an OS that has been deployed, in some cases, it is necessary to tighten security during the design and coding of the OS. This is called OS hardening. An OS that has been designed in this way to be secure is a *trusted OS*.

For a Microsoft Windows endpoint computer, it is also important to secure the **registry**, which is a database that contains low-level settings used by the Windows OS and for those applications that use the registry. Threat actors who can modify the registry could be able to disable antivirus and antimalware protections, disable any cloud-delivered protection, and remove security updates.

To mitigate this risk, the Windows 10 Tamper Protection security feature prevents Windows security settings from being changed or disabled by a threat actor who modifies the registry. Instead, the security settings can only be accessed directly through the Windows 10 user interface or through enterprise management software.

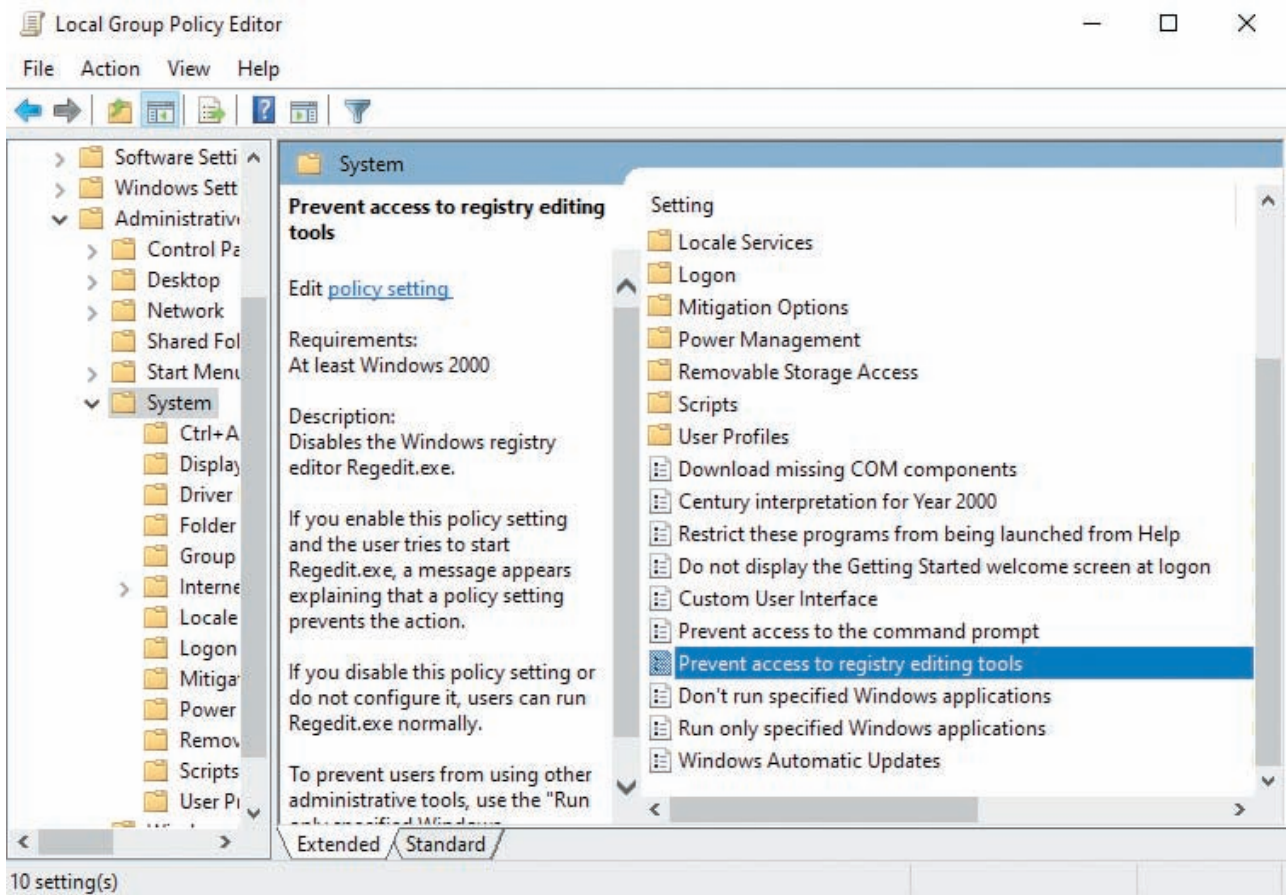
In addition to Tamper Protection, a Group Policy setting can prevent access to the tool that can alter the registry. This setting is *Prevent access to registry editing tools* and is shown in Figure 4-7.

Confinement Tools Several tools can be used to “confine” or restrict malware. These tools include the following:

- *Application whitelisting/blacklisting.* An increasingly popular approach to client OS security is to employ **application whitelisting/blacklisting**. **Whitelisting** is approving in advance only specific applications to run on the OS so that any item not approved is either restricted or denied (“default-deny”). The inverse of whitelisting is **blacklisting**, creating a list of unapproved software so that any item not on the list of blacklisted applications can run (“default-allow”). Application whitelisting/blacklisting requires preapproval for an application to run or not run.

NOTE 20

The elite Tailored Access Operations (TAO) section of the National Security Agency (NSA) is responsible for compromising networks owned by hostile nations to spy on them. The head of the TAO spoke at a security conference about the best practices of security from the NSA’s perspective (in his own words, “what can you do to defend yourself to make my life hard?”). One of the most important steps was to employ whitelisting for the software that runs on servers. A similar step is to whitelist a predefined set of websites to which users can connect to prevent malware from accessing a C&C or to exfiltrate stolen information.³



Source: Used with permissions from Microsoft

Figure 4-7 Prevent access to registry editing tools

- **Sandbox.** Figure 4-8 illustrates a conceptual view of applications that interact with an OS. A **sandbox** is a “container” in which an application can be run so that it does not impact the underlying OS, as illustrated in Figure 4-9. Anything that occurs within the sandbox is not visible to other applications or the OS outside the sandbox. Also, the contents of the sandbox are not saved when the sandbox is closed. Sandboxes are often used when downloading or running suspicious programs to ensure that the endpoint will not become infected.
- **Quarantine.** Whereas a sandbox is used to contain an *application*, **quarantine** is a process that holds a suspicious *document*. Quarantine is most commonly used with email attachments. When an attachment is received, the quarantine process removes the attachment and, depending upon the policy set by the organization, either sends to the user sent a sanitized version of the attachment (such as a Word DOCX document that has been converted to a PDF document) or a URL to the document on a restricted computer so that the user can view, print, or delete the attachment.

NOTE 21

A sandbox is not the same as a virtual machine. A virtual machine is a “computer within a computer” in which an entire OS runs as an application on top of the regular OS. However, its contents can be saved for future use.

NOTE 22

Microsoft Office documents that are received as attachments, opened from an Internet location, or opened from an unsafe location are by default quarantined. The documents are displayed in Protected View, which is a read-only mode with most editing functions disabled. If the file needs to be saved or printed, the user can click the “Enable Editing” button to open the document as normal.

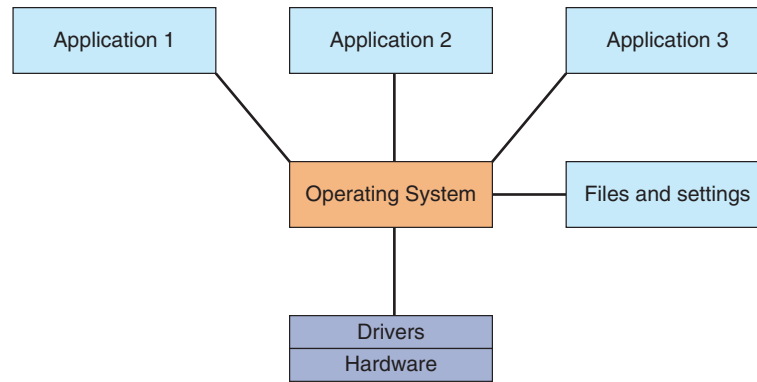


Figure 4-8 Applications interacting with an OS

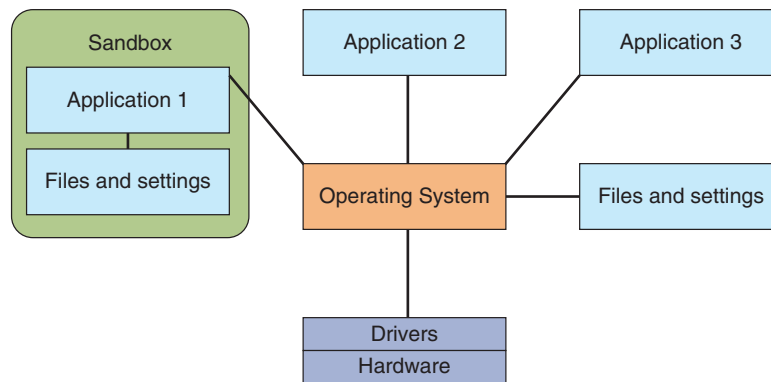


Figure 4-9 Using a sandbox

TWO RIGHTS & A WRONG

1. In a Trusted Boot, the endpoint's firmware logs the boot process to the OS can send it to a trusted server to assess the security.
2. Dynamic analysis uses heuristic monitoring.
3. Cookies are a workaround of the stateless protocol HTTP.

See Appendix B for the answer.

CREATING AND DEPLOYING SECDEVOPS

CERTIFICATION

2.3 Summarize secure application development, deployment, and automation concepts.

3.2 Given a scenario, implement host or application security solutions.

Confirming boot integrity, protecting endpoints, and hardening endpoints are all essential steps in securing an endpoint computer. But an additional element that is also critical is creating and deploying secure applications. Because endpoint computers run applications, the best endpoint boot security, antivirus and antimalware, patch management, and OS security configurations can all be negatively impacted—and sometimes negated—by an application that contains vulnerabilities. An unsecure application can open the door for attackers to exploit the application, the data that it uses, and even the underlying OS. Table 4-5 lists attacks that can be launched using vulnerabilities in applications.

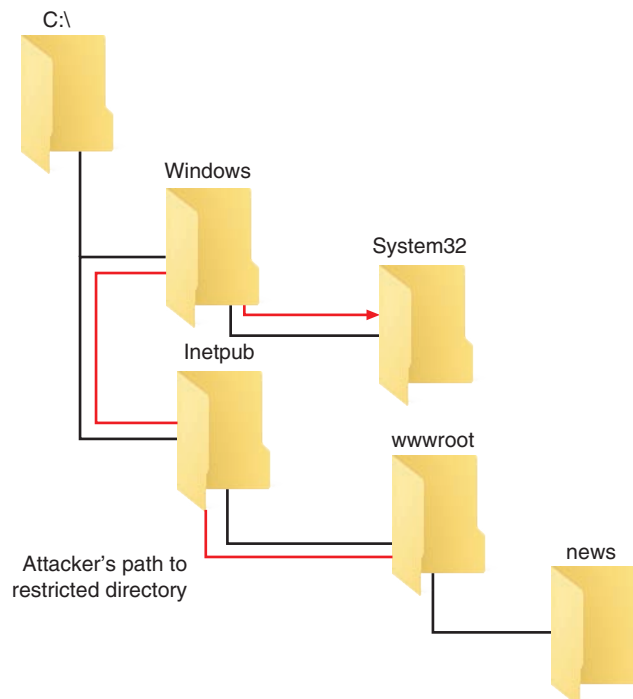
Table 4-5 Attacks based on application vulnerabilities

Attack	Description	Defense
Executable files attack	Trick the vulnerable application into modifying or creating executable files on the system	Prevent the application from creating or modifying executable files for its proper function
System tampering	Use the vulnerable application to modify special sensitive areas of the operating system (Microsoft Windows registry keys, system startup files, etc.) and take advantage of those modifications	Do not allow applications to modify special areas of the OS
Process spawning control	Trick the vulnerable application into spawning executable files on the system	Take away the process spawning ability from the application

One particularly dangerous attack can be the result of a vulnerability in an application. The *root directory* is a specific directory on a web server's file system, and users who access the server are usually restricted to the root directory and directories and files beneath the root directory, but they cannot access other directories. For example, the default root directory of Microsoft's Internet Information Services (IIS) web server is `C:\inetpub\wwwroot`. Users have access to this directory and subdirectories beneath this root (`C:\inetpub\wwwroot\news`) if given permission, but they do not have access to other directories in the file system, such as `C:\Windows\System32`. A **directory traversal** attack takes advantage of vulnerability in the web application program or the web server software so that a user can move from the root directory to other restricted directories. The ability to move to another directory could allow an unauthorized user to view confidential files or even enter commands to execute on a server known as *command injection*. A directory traversal attack is illustrated in Figure 4-10. Other dangerous weaknesses in an application can create vulnerabilities in computer memory or buffer areas that can be easily exploited. These poor **memory management** vulnerabilities result in attacks such as buffer overflow, integer overflow, pointer/object dereference, and DLL injection attacks.

NOTE 23

Buffer overflow, integer overflow, pointer/object dereference, and DLL injection attacks are all covered in Module 3.

**Figure 4-10** Directory traversal attack

The cause of most unsecure applications is usually the result of how the application was designed and written. Creating and developing secure software involves understanding application development concepts, secure coding techniques, and code testing.

Application Development Concepts

The two levels of application development concepts include general concepts that apply to all application development and those that apply to a more rigorous security-based approach.

General Concepts

Developing an application requires completing several stages. These stages include the following:

- *Development.* At the **development stage**, the requirements for the application are established, and it is confirmed that the application meets the intended business needs before the actual coding begins.
- *Testing.* The **testing stage** thoroughly tests the application for any errors that could result in a security vulnerability.
- *Staging.* The **staging stage** tests to verify that the code functions as intended.
- *Production.* In the **production stage** the application is released to be used in its actual setting.

Often application development will involve **software diversity**. Software diversity is a software development technique in which two or more functionally identical variants of a program are developed from the same specification but by different programmers or programming teams. The intent is to provide error detection, increased reliability, and additional documentation. It also can reduce the probability that errors created by different **compilers**, which are programs that create **binary** machine code from human source code, will influence the end results.

Another concept regarding application development involves how the completed application will be used in the context of the larger IT footprint of the enterprise. **Provisioning** is the enterprise-wide configuration, deployment, and management of multiple types of IT system resources, of which the new application would be viewed as a new resource. **Deprovisioning** in application development is removing a resource that is no longer needed.

Integrity measurement is an “attestation mechanism” designed to be able to convince a remote party (external to the coding team) that an application is running only a set of known and approved executables. Whenever a file is called in an executable mode, such as when a program is invoked or a sharable library is mapped, the integrity measurement tool generates a unique digital value of that file. On request, the tool can produce a list of all programs run and their corresponding digital values. This list can then be examined to ensure that no unknown or known vulnerable applications have been run.

SecDevOps

An *application development lifecycle model* is a conceptual model that describes the stages involved in creating an application. Most projects use one of two major application development lifecycle models.

The *waterfall model* uses a sequential design process: as each stage is fully completed, the developers move on to the next stage. This means that once a stage is finished, developers cannot go back to a previous stage without starting all over again. For example, in the waterfall model, **quality assurance (QA)**—verification of quality—occurs only after the application has been tested and before it is finally placed in production. However, this makes any issues uncovered by QA difficult to address since it is at the end of the process. The waterfall model demands extensive planning in the very beginning and requires that it be followed carefully.

The *agile model* was designed to overcome the disadvantages of the waterfall model. Instead of following a rigid sequential design process, the agile model takes an incremental approach. Developers might start with a simplistic project design and begin to work on small modules. The work on these modules is done in short (weekly or monthly) “sprints,” and at the end of each sprint, the project’s priorities are again evaluated as tests are being run. This approach allows for software issues to be incrementally discovered so that feedback and changes can be incorporated into the design before the next sprint is started.

One specific type of software methodology that follows the agile model and heavily incorporates **secure coding practices and techniques** to create secure software applications is called *SecDevOps*. SecDevOps (also known as DevSecOps and DevOpsSec) is the process of integrating secure development best practices and methodologies

into application software development and deployment processes using the agile model. It is a set of best practices designed to help organizations implant secure coding deep in the heart of their applications.

SecDevOps is often promoted in terms of its **elasticity** (flexibility or resilience in code development) and its **scalability** (expandability from small projects to very large projects). However, the cornerstone of SecDevOps is automation. With standard application development, security teams often find themselves stuck with time-consuming manual tasks. SecDevOps, on the other hand, applies what is called **automated courses of action** to develop the code as quickly and securely as possible. This automation enables **continuous monitoring** (examining the processes in real time instead of at the end of a stage), **continuous validation** (ongoing approvals of the code), **continuous integration** (ensuring that security features are incorporated at each stage), **continuous delivery** (moving the code to each stage as it is completed), and **continuous deployment** (continual code implementation).

NOTE 24

The SecDevOps methodology also includes concepts such as *immutable systems* (once a value or configuration is employed as part of an application, it is not modified; if changes are necessary, a new system must be created), *infrastructure as code* (managing a hardware and software infrastructure using the same principles as developing computer code), and *baselining* (creating a starting point for comparison purposes in order to apply targets and goals to measure success).

Table 4-6 lists sources of recommendations for SecDevOps.

Table 4-6 Secure SDLC sources

Source	Description	Materials available
OWASP (Open Web Application Security Project)	A group that monitors web attacks	Maturity models, development guides, testing guides, code review guides, and application security verification standards
SANS (SysAdmin, Audit, Network and Security Institute)	A company that specializes in cybersecurity and secure web application development	White papers, research reports, and best practices guidelines
CIS (Center for Internet Security)	Not-for-profit organization that compiles CIS security controls	Training, assessment tools, and consulting services

Because SecDevOps is based on the agile method, it involves continuous modifications throughout the process. With these continual changes, it is important to use tools that support change management or creating a plan for documenting changes to the application. One tool for change management is **version control** software that allows changes to be automatically recorded and, if necessary, “rolled back” to a previous version of the software.

Secure Coding Techniques

Several coding techniques should be used to create secure applications and limit **data exposure** or disclosing sensitive data to attackers. These techniques include determining how encryption will be implemented and ensuring that memory management is handled correctly so as not to introduce memory vulnerabilities. Other techniques are summarized in Table 4-7.

Code Testing

Testing is one of the most important steps in SecDevOps. Instead of testing only after the application is completed, testing should be performed much earlier during the implementation and verification phases of a software development process. Testing involves static code analysis and dynamic code analysis.

NOTE 25

Edsger W. Dijkstra, a famous software engineer, once said, “Program testing can be used to show the presence of bugs, but never to show their absence!”

Table 4-7 Secure coding techniques

Coding technique	Description	Security advantage
Proper input validation	Accounting for errors such as incorrect user input (entering a file name for a file that does not exist).	Can prevent Cross-site scripting (XSS) and Cross-site request forgery (CSRF) attacks
Normalization	Organizing data within a database to minimize redundancy.	Reduces footprint of data exposed to attackers
Stored procedure	A subroutine available to applications that access a relational database.	Eliminates the need to write a subroutine that could have vulnerabilities
Code signing	Digitally signing applications.	Confirms the software author and guarantees the code has not been altered or corrupted
Obfuscation/ camouflaged code	Writing an application in such a way that its inner functionality is difficult for an outsider to understand.	Helps prevent an attacker from understanding a program's function
Dead code	A section of an application that executes but performs no meaningful function.	Provides an unnecessary attack vector for attackers
Server-side execution and validation or Client-side execution and validation	Input validation generally uses the server to perform validation but can also have the client perform validation by the user's web browser.	Adds another validation to the process
Code reuse of third-party libraries and SDKs	Code reuse is using existing software in a new application; a software development kit (SDK) is a set of tools used to write applications.	Existing libraries that have already been vetted as secure eliminate the need to write new code

Static Code Analysis

Analysis and testing of the software should occur from a security perspective before the source code is even compiled. These tests are called **static code analysis**. Figure 4-11 illustrates an automated static code analysis tool.

Automated static code analysis may also be accompanied by **manual peer reviews**. In these reviews, software engineers and developers are paired together or grouped in larger teams to laboriously examine each line of source code, looking for vulnerabilities.

Dynamic Code Analysis

Security testing should also be performed after the source code is compiled (a process called **dynamic code analysis** or *run-time verification*) and when all components are integrated and running. This testing typically uses a tool or suite of pre-built attacks or testing tools that specifically monitor the application's behavior for memory corruption, user privilege issues, and other critical security problems.

Some of the most common dynamic code analysis tools use a process called **fuzzing**. Fuzzing provides random input to a program in an attempt to trigger exceptions, such as memory corruption, program crashes, or security breaches. An advantage of fuzzing is that it produces a record of what input triggered the exception so it can be reproduced to track down the problem within the code. Fuzzing test software consists of an *execution engine* and an *input generator*, which usually allows the tester to configure the types of inputs (see Figure 4-12).



CAUTION

A single pass of a fuzzer is unlikely to find all exceptions in software due to the randomness in the fuzzing process. The mutation of the inputs relies on randomness to determine where to mutate input and what to mutate. Fuzzers require multiple trials and statistical tests.

Home › cs-foo.m › cs-foo.m analysis 1 › Warning 2659.7263

< Prev (Warning 1 of 4) Next >

Division By Zero[?] at foo.m:30

[Jump to warning location ↓](#)

No properties have been set.
[warning details...](#)

[edit properties](#)

Show Events | Options

main() /Users/abhaskar/scratch/foo.m

```
24 int main() {
25     Foo *foo = [[Foo alloc] init];
26 [-] int ten = [foo getBaseNumber];
```

L [-Base getBaseNumber]() /Users/abhaskar/scratch/foo.m

```
9 -(int)getBaseNumber {
10     return 10;
    Event 1: [-Base getBaseNumber]() returns 10. ▼ hide
```

Event 2: ten is set to [foo getBaseNumber], which evaluates to 10. See related event 1. ▲ ▼ hide

```
27 [-] int minus_ten = [foo getNumber]; // CodeSonar is able to resolve
```

L [-Foo getNumber]() /Users/abhaskar/scratch/foo.m

```
19 -(int)getNumber {
20     return -10;
    Event 3: [-Foo getNumber]() returns -10. ▲ ▼ hide
```

Event 4: minus_ten is set to [foo getNumber], which evaluates to -10. See related event 3. ▲ ▼ hide

```
28 // both the above message sends.
29
30
```

```
int dbz = 1 / (ten + minus_ten);
Division By Zero?
A value is divided by 0.
The issue can occur if the highlighted code executes.
See related events 2 and 4.
Show: All events | Only primary events
```

Source: GrammarTech

Figure 4-11 Automated static code analysis tool

TWO RIGHTS & A WRONG

1. A goal of software diversity is to reduce the probability that errors created by different compilers will influence the end results.
2. Provisioning is removing a resource that is no longer needed.
3. SecDevOps has elasticity and scalability.

See Appendix B for the answer.

VM LAB

You're now ready to complete the live virtual machine labs for this module. The labs can be found in each module in the MindTap.

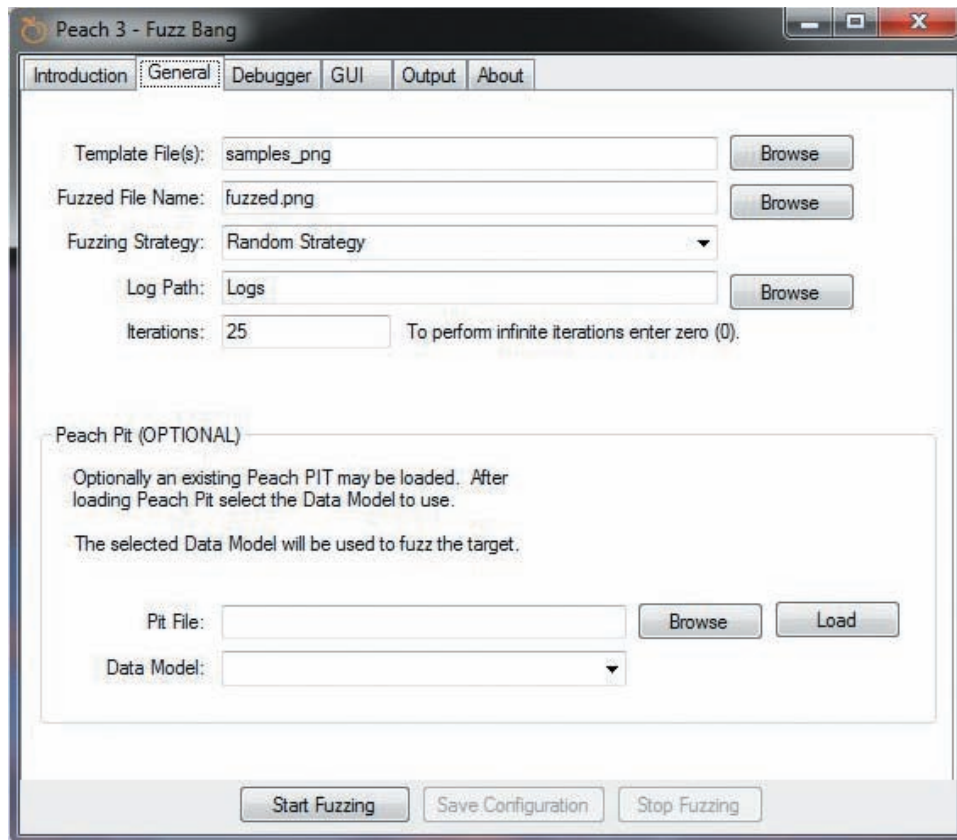


Figure 4-12 Fuzzer input generator

SUMMARY

- Organizations are pooling their experiences and knowledge gained about the latest attacks with the broader security community because sharing this type of information has become an important aid to help other organizations shore up their defenses. Open source threat intelligence information that is freely available, often called open source intelligence (OSINT), has become a vital resource. This information is often collected and then disseminated through public information sharing centers. The two concerns around public information sharing centers are the privacy of shared information and the speed at which the information is shared. Closed source is the opposite of open source. Organizations that are participants in closed source information are part of private information sharing centers that restrict both access to data and participation.
- Several sources of threat intelligence are useful. A vulnerability database is a repository of known vulnerabilities and information as to how they have been exploited. These databases create “feeds” of the latest cybersecurity incidences. A cybersecurity threat map illustrates cyberthreats overlaid on a diagrammatic representation of a geographical area. Threat maps help in visualizing attacks and provide a limited amount of context of the source and the target countries, the attack types, and historical and near real-time data about threats, although they provide limited valuable information. File and code repositories are used by victims of an attack who can upload malicious files and software code that can then be examined by others to learn more about these attacks and craft their defenses. The dark web is the domain of threat actors and beyond the reach of a normal search engine. Malicious activity such as selling drugs and stolen personal information and buying and selling malicious software used for attacks occurs on the dark web. Some security professionals and organizations use the dark web on a limited basis to look for signs that information critical to that enterprise is being sought out or sold on the dark web.

- One of the steps that is often overlooked in securing endpoint computers is to confirm that the computer has started without any malicious activity taking place. The booting process on early personal computers used firmware called the BIOS (Basic Input/Output System). Although the ability to update the BIOS firmware enabled new features to be added, it also opened the door for threat actors to create malware to infect the BIOS. To combat this vulnerability and add functionality, UEFI (Unified Extensible Firmware Interface) was developed, in conjunction with the Secure Boot security standard. Several techniques can be used to assure boot security by taking advantage of the features in UEFI.
- Antivirus (AV) software can examine a computer for any file-based virus infections and monitor computer activity and scan new documents that might contain a virus. A new approach to AV is dynamic analysis, which uses a variety of techniques to spot the characteristics of a virus instead of attempting to make matches. Antimalware is a suite of software intended to provide protections against multiple types of malware, such as ransomware, cryptomalware, Trojans, spam, and spyware.
- Web browsers have a degree of security that can protect endpoint computers. User-specific information stored in a file on the user's local computer is called a cookie. There are several types of cookies. As a means of protection for cookies, a web browser can send a secure cookie. This cookie is only sent to the server with an encrypted request over the secure HTTPS protocol. When a user visits a website through their web browser, the web server answers back with HTTP Response Headers. These headers tell the browser how to behave while communicating with the website. Several HTTP Response Headers can improve security.
- A host intrusion detection system (HIDS) is a software-based application that runs on an endpoint computer and can detect that an attack has occurred. The primary function of a HIDS is automated detection, which saves someone from sorting through log files to find an indication of unusual behavior. A HIDS relies on agents installed directly on the endpoint, and these agents work closely with the OS to observe activity. A host intrusion prevention system (HIPS) monitors endpoint activity to immediately react to block a malicious attack by following specific rules. Activity that a HIPS watches for includes an event that attempts to control other programs, terminate programs, and install devices and drivers. Endpoint detection and response (EDR) tools have a similar functionality to HIDS of monitoring endpoint events and of HIPS of taking immediate action. However, EDR tools are considered more robust than HIDS and HIPS.
- One of the most important steps in securing an endpoint computer is to promptly install patches. Modern operating systems—such as Red Hat Linux, Apple macOS, Ubuntu Linux, and Microsoft Windows—frequently distribute patches. A growing number of application and utility software developers are also distributing patches called third-party updates. An automated patch update service is used to manage patches within the enterprise instead of relying upon the vendor's online update service. Early versions of OSs allowed users to configure how they receive patches; however, today patches are usually automatically downloaded and installed whenever they become available.
- An unsecure application can open the door for attackers to exploit the application, the data that it uses, and even the underlying OS. The cause of most unsecure applications is usually the result of how the application was designed and written. Developing an application requires several stages. An application development lifecycle model is a conceptual model that describes the stages involved in creating an application. The waterfall model uses a sequential design process: as each stage is fully completed, the developers move on to the next stage. The agile model was designed to overcome the disadvantages of the waterfall model. Instead of following a rigid sequential design process, the agile model takes an incremental approach. One specific type of software methodology that follows the agile model and heavily incorporates secure coding practices and techniques to create secure software applications is called SecDevOps. Several coding techniques should be used to create secure applications and limit data exposure or disclosing sensitive data to attackers. These techniques include determining how encryption will be implemented and ensuring that memory management is handled correctly so as to not introduce memory vulnerabilities.
- Testing is one of the most important steps in SecDevOps. Yet, instead of testing only after the application is completed, testing should be performed much earlier during the implementation and verification phases of a software development process. Analysis and testing of the software should occur from a security perspective before the source code is even compiled. These tests are called static code analysis. Security testing should also be performed after the source code is compiled (a process called dynamic code analysis).

Key Terms

antimalware	disabling unnecessary open ports and services	provisioning
antivirus (AV)	dynamic code analysis	public information sharing centers
application whitelisting/blacklisting	elasticity	quality assurance (QA)
automated courses of action	endpoint detection and response (EDR)	quarantine
Automated Indicator Sharing (AIS)	file and code repositories	registry
auto-update	fuzzing	sandbox
binary	hardware root of trust	scalability
blacklisting	host intrusion detection system (HIDS)	secure coding practices and techniques
boot attestation	host intrusion prevention system (HIPS)	secure cookie
client-side execution and validation	HTTP Response Headers	server-side execution and validation
closed source	indicator of compromise (IOC)	software diversity
code reuse of third-party libraries and SDKs	integrity measurement	staging stage
code signing	manual peer reviews	static code analysis
compilers	Measured Boot	stored procedure
continuous delivery	memory management	Structured Threat Information Expression (STIX)
continuous deployment	normalization	testing stage
continuous integration	obfuscation/camouflaged code	third-party updates
continuous monitoring	open source	threat map
continuous validation	OWASP (Open Web Application Security Project)	Trusted Automated Exchange of Intelligence Information (TAXII)
dark web	predictive analysis	UEFI (Unified Extensible Firmware Interface)
data exposure	private information sharing centers	version control
dead code	production stage	vulnerability database
deprovisioning	proper input validation	whitelisting
development stage		
directory traversal		

Review Questions

- An IOC occurs when what metric exceeds its normal bounds?
 - IRR
 - LRG
 - EXR
 - KRI
- What are the two concerns about using public information sharing centers?
 - Cost and availability
 - Privacy and speed
 - Security and privacy
 - Regulatory approval and sharing
- Which privacy protection uses four colors to indicate the expected sharing limitations that are to be applied by recipients of the information?
 - CISA
 - FOIA
 - TLP
 - PCII
- Oskar has been receiving emails about critical threat intelligence information from a public information sharing center. His team leader has asked him to look into how the process can be automated so that the information can feed directly into the team's technology security. What technology will Oskar recommend?
 - Automated Indicator Sharing (AIS)
 - Bidirectional Security Protocol (BSP)
 - Linefeed Access
 - Lightwire JSON Control
- Which of the following is an application protocol for exchanging cyberthreat intelligence over HTTPS?
 - STIX
 - AIP-TAR

- c. TAXII
 - d. TCP-Over-Secure (ToP)
6. What are the two limitations of private information sharing centers?
- a. Access to data and participation
 - b. Government approval and cost
 - c. Timing of reports and remote access
 - d. Bandwidth and CPU
7. Which of the following is NOT a limitation of a threat map?
- a. Many maps claim that they show data in real time, but most are simply a playback of previous attacks.
 - b. Because threat maps show anonymized data, it is impossible to know the identity of the attackers or the victims.
 - c. They can be difficult to visualize.
 - d. Threat actors usually mask their real locations, so what is displayed on a threat map is incorrect.
8. Luka has been asked by his supervisor to monitor the dark web for any IOCs concerning their organization. The next week, Luca reports that he was unable to find anything because looking for information on the dark web is different from using the regular web. Which of the following is FALSE about looking for information on the dark web?
- a. It is necessary to use Tor or IP2.
 - b. Dark web search engines are identical to regular search engines.
 - c. Dark web merchants open and close their sites without warning.
 - d. The naming structure is different on the dark web.
9. Which of the following is NOT an improvement of UEFI over BIOS?
- a. Stronger boot security
 - b. Networking functionality in UEFI
 - c. Access larger hard drives
 - d. Support of USB 3.0
10. Which boot security mode sends information on the boot process to a remote server?
- a. UEFI Native Mode
 - b. Secure Boot
 - c. Trusted Boot
 - d. Measured Boot
11. Which of the following is NOT an important OS security configuration?
- a. Employing least functionality
 - b. Disabling default accounts
 - c. Disabling unnecessary services
 - d. Restricting patch management
12. Which stage conducts a test that will verify the code functions as intended?
- a. Production stage
 - b. Testing stage
 - c. Staging stage
 - d. Development stage
13. Which model uses a sequential design process?
- a. Secure model
 - b. Agile model
 - c. Rigid model
 - d. Waterfall model
14. Which of the following is NOT an advantage of an automated patch update service?
- a. Downloading patches from a local server instead of using the vendor's online update service can save bandwidth and time because each computer does not have to connect to an external server.
 - b. Administrators can approve updates for "detection" only; this allows them to see which computers require the update without installing it.
 - c. Users can disable or circumvent updates just as they can if their computer is configured to use the vendor's online update service.
 - d. Administrators can approve or decline updates for client systems, force updates to install by a specific date, and obtain reports on what updates each computer needs.
15. What type of analysis is heuristic monitoring based on?
- a. Dynamic analysis
 - b. Static analysis
 - c. Code analysis
 - d. Input analysis
16. Which of these is a list of preapproved applications?
- a. Greenlist
 - b. Redlist
 - c. Blacklist
 - d. Whitelist
17. What is the advantage of a secure cookie?
- a. It cannot be stored on the local computer without the user's express permission.
 - b. It is sent to the server over HTTPS.
 - c. It is analyzed by AV before it is transmitted.
 - d. It only exists in RAM and is deleted once the web browser is closed.
18. Which of the following tries to detect and stop an attack?
- a. HIDS
 - b. HIPS
 - c. RDE
 - d. SOMA

19. What does Windows 10 Tamper Protection do?
- Limits access to the registry.
 - Prevents any updates to the registry until the user approves the update.
 - Compresses and locks the registry.
 - Creates a secure backup copy of the registry.
20. Which of the following is FALSE about a quarantine process?
- It holds a suspicious application until the user gives approval.
 - It can send a sanitized version of the attachment.
 - It can send a URL to the document that is on a restricted computer.
 - It is most often used with email attachments.

Hands-On Projects

CAUTION

If you are concerned about installing any of the software in these projects on your regular computer, you can instead install the software in the Windows in the Microsoft Sandbox or a virtual machine created in the Module 1 Hands-On Projects. Software installed within the virtual machine will not impact the host computer.

Project 4-1: Using the Microsoft Online Security Bulletins

Time Required: 20 minutes

Objective: Explain different threat actors, vectors, and intelligence sources.

Description: Microsoft has made its security bulletins available in a searchable online database. All security professionals need to be familiar with using this database. In this project, you will explore the online database.

- Open your web browser and enter the URL **portal.msrc.microsoft.com/en-us/**. (The location of content on the Internet may change without warning. If you are no longer able to access the program through this URL, use a search engine to search for "Microsoft Security Response Center.")
- Click **Read the Security Update Guide FAQ**.
- Click **Expand all** to read through the information.
- Click the link **www.icasi.org/cvrf/** (or enter it into another tab in your browser). What is the Common Vulnerability Reporting Framework (CVRF)? How is it used?
- Return to the Microsoft Security Update Guide and then the MSRC main page.
- Click the **Go to the Security Update Guide** button.
- If no security updates appear, adjust the **From** date to the first day of the previous month.
- Scroll through the list of security updates.
- Click the first link under **Article**.
- Read through this information.
- Now return to the previous page and select another article to read.
- How useful is this information? Is it presented in a format that is helpful?
- Now click the CVE link under **Details** and read this information. Note the detail of this information.
- Read the information under **Exploitability Assessment** (if the exploit you selected does not list an Exploitability Assessment, then select another that does include the assessment). What does this mean? Open another tab on your web browser, and search for **Microsoft Exploitability Index**. Read through the description that you find and keep this tab open.
- Return to the Microsoft Security Update Guide and view the **Exploitability Assessment**. How serious is this security vulnerability?
- How important is this information to a security professional? How easy is this online database to use?
- Now compare the Microsoft database with Apple's. Enter the URL **support.apple.com/en-us/HT201222**. (The location of content on the Internet may change without warning. If you are no longer able to access the program through the above URL, use a search engine to search for "Apple Security Updates.")
- Scroll down through the list of Apple security updates. How does this list compare with the updates from Microsoft?
- Select a recent event under **Name and information link**.

20. Read the information about the update. How does this information compare with Microsoft's information? Why is there such a difference? Which provides better information for security professions?
21. Close all windows.

Project 4-2: Setting Windows Local Security Policy

Time Required: 20 minutes

Objective: Given a scenario, implement host or application security solutions.

Description: The Local Group Policy Editor is a Microsoft Management Console (MMC) snap-in that gives a single user interface through which all the Computer Configuration and User Configuration settings of Local Group Policy objects can be managed. The Local Security Policy settings are among the security settings contained in the Local Group Policy Editor. An administrator can use these to set policies that are applied to the computer. In this project, you will view and change local security policy settings.



CAUTION

You will need to be an administrator to open the Local Group Policy Editor.

1. Click **Start**.
2. Type **secpol.msc** into the Search box, and then click **secpol**.

NOTE 26

If your computer is already joined to a domain then searching for secpol.msc might not launch the application. If this is the case, click **Start** and type **mmc.msc**. On the File menu, click **Add/Remove** snap-in, and then click **Add**. In **Add Standalone Snap-in**, double-click **Group Policy Object Editor**.

3. First create a policy regarding passwords. Expand **Account Policies** in the left pane, and then expand **Password Policy**.
4. Double-click **Enforce password history** in the right pane. This setting defines how many previously used passwords Windows will record. This prevents users from "recycling" old passwords.
5. Change **passwords remembered** to **4**.
6. Click **OK**.
7. Double-click **Maximum password age** in the right pane. The default value is 42, meaning that a user must change his password after 42 days.
8. Change **days** to **30**.
9. Click **OK**.
10. Double-click **Minimum password length** in the right pane. The default value is a length of eight characters.
11. Change **characters** to **10**.
12. Click **OK**.
13. Double-click **Password must meet complexity requirements** in the right pane. This setting forces a password to include at least two opposite case letters, a number, and a special character (such as a punctuation mark).
14. Click **Enabled**.
15. Click **OK**.
16. Double-click **Store passwords using reversible encryption** in the right pane. Because passwords should be stored in an encrypted format, this setting should not be enabled.
17. If necessary, click **Disabled**.
18. Click **OK**.
19. In the left pane, click **Account lockout policy**.
20. Double-click **Account lockout threshold** in the right pane. This is the number of times that a user can enter an incorrect password before Windows will lock the account from being accessed. (This prevents an attacker from attempting to guess the password with unlimited attempts.)
21. Change **invalid login attempts** to **5**.
22. Click **OK**.
23. Note that the Local Security Policy suggests changing the **Account lockout duration** and the **Reset account lockout counter after** values to 30 minutes.

24. Click **OK**.
25. Expand **Local Policies** in the left pane, and then click **Audit Policy**.
26. Double-click **Audit account logon events**.
27. Check both **Success** and **Failure**.
28. Click **OK**.
29. Right-click **Security Settings** in the left pane.
30. Click **Reload** to have these policies applied.
31. Close all windows.

Project 4-3: Configuring Microsoft Windows Security—Part 1

Time Required: 15 minutes

Objective: Given a scenario, implement host or application security solutions.

Description: It is important that security settings be properly configured on a computer in order to protect it. In this project, you examine several security settings on a Microsoft Windows 10 computer using the Windows interface.



CAUTION

This project shows how to configure Windows security for a personal computer. If this computer is part of a computer lab or office, these settings should not be changed without the proper permissions.

1. Click **Start** and **Settings**.
2. Click **Update and security**.
3. If necessary, click **Windows Update** in the left pane.
4. Click **Pause updates for 7 days**. What warning are you given?
5. Click **Resume updates**.
6. Click **View update history**.
7. Expand each area and select one update to review. Read through the information on the update. How detailed is this information?
8. Return to the **View update history** page.
9. Return to the **Windows Update** page.
10. Click **Advanced options**.
11. Be sure that **Receive updates for other Microsoft products when you update Windows** is set to **On**. This will allow for updates for Microsoft software such as Office to also be updated.
12. Read the information under **Pause updates**. Why would you select this option?
13. Click the down arrow under **A quality update includes security improvements. It can be deferred for this many days**. How many days can you defer security updates?
14. Return to the **Windows Update** page.
15. In the left pane, click **Windows Security**.
16. Click **Virus & threat protection**.
17. Click **Scan options** and be sure that **Quick scan** is selected.
18. Now perform a Quick scan of the most essential files. Click **Scan now**. Depending upon your system, it may take several minutes to complete. What was the result of the scan?
19. Return to the Virus & threat protection page. Under **Virus & threat protection settings**, click **Manage settings**.
20. Read through the details of the options. Are there any that you would change? Why?
21. Close all windows.

Project 4-4: Configuring Microsoft Windows Security—Part 2

Time Required: 15 minutes

Objective: Given a scenario, implement host or application security solutions.

Description: As seen from Project 4-3, Windows security settings are found across several different screens. This can make it easy to overlook important settings and time consuming to fine-tune the settings, especially when configuring

the Windows Defender virus and threat protection product. A third-party tool called ConfigureDefender provides an easier interface. In this project, you will download and use the ConfigureDefender product.

NOTE 27

ConfigureDefender is not installed on the computer but runs as a stand-alone application.

1. Open your web browser and enter the URL **github.com/AndyFul/ConfigureDefender** (if you are no longer able to access the program through the URL, use a search engine to search for “ConfigureDefender”).
2. Find the latest version of ConfigureDefender (the program is compressed in a ZIP file). Click the filename.
3. Click **Download**.
4. After the file has downloaded, unpack it, and then launch the program.
5. Click the **Info about Defender** button to see the computer’s Defender settings. When finished, close the window.
6. Click the **Defender Security Log** button. Read the log file about recent actions. Does anything surprise you? When finished, close the window.
7. Scroll down and read the different settings. Were you aware that there were so many different options for Windows Defender?
8. Hover over the **DEFAULT** button and read the information.
9. Now hover over the **HIGH** button and read the information.
10. Click the **HIGH** button, and then close the pop-up box.
11. Scroll down through the settings. How much stronger are they than from the Default settings?
12. Now hover over the **MAX** button and read the information.
13. Click the **MAX** button, and then close the pop-up box.
14. Scroll down through the settings. How much stronger are they?
15. Finally click either the **DEFAULT** or **HIGH** button to set your computer at the security level that you choose.
16. How easy is ConfigureDefender to use? Would you recommend it to others?
17. Close all windows.

Case Projects

Case Project 4-1: AV Comparison

Select four antivirus products, one of which is a free product, and compare their features. Create a table that lists the features. How do they compare with the AV software you currently use? Which would you recommend to others? Why? Create a report on your research.

Case Project 4-2: Threat Maps

Locate four online cybersecurity threat maps. Compare their real-time results. Why are these results different? What type of information do they provide? How easy or hard are they to use? How could they be used? How should they not be used? What are the strengths? What are the weaknesses? What recommendations would you make for improving host security? Write a one-page paper on your analysis.

Case Project 4-3: Application Patch Management

Select four third-party applications (not OSs) that you frequently use. How does each of them address patch management? Visit their websites to determine how they alert users to new vulnerabilities. Are the patch management systems adequate? Should patch management be required of all third-party applications? What are the advantages? What are the disadvantages? Write a one-page paper on your findings.

Case Project 4-4: UEFI

Use the Internet to research UEFI. What are its advantages? What are its disadvantages? What criticisms have been leveled against it? Do you agree with the criticism? Write a one-page paper on your findings.

Case Project 4-5: STIX and TAXII

Research the Internet to find information on STIX and TAXII. How are they used? What formats do they provide? How widely are they used? What are their strengths and weaknesses? Write a one-page paper on your findings.

Case Project 4-6 Information Security Community Site Activity

The Information Security Community Site is an online companion to this textbook. It contains a wide variety of tools, information, discussion boards, and other features to assist learners. In order to gain the most benefit from the site, you will need to set up a free account.

Go to **community.cengage.com/infosec2**. Post your thoughts about the following: *Should the dark web be shut down?* What would be the advantages? What would it take for this to happen? What would threat actors do if it were suddenly unavailable? Is there any impact on free speech? Does free speech protect criminal enterprises? What do you think?

Case Project 4-7 North Ridge Security

North Ridge Security provides security consulting and assurance services. You have recently been hired as an intern to assist this organization.

You have been asked to prepare a presentation on SecDevOps for a group of students studying programming at a local college.

1. Create a PowerPoint presentation on SecDevOps, how it compares to standard application development, how it is different, and how it works. Your presentation should be at least seven slides in length.
2. As a follow-up to your presentation, you have been asked to write a one-page report on fuzzing. Use the Internet to research fuzzing, how it can be used, its strengths and weaknesses, and your recommendations.

References

1. Porter, Jon, "The PC market just had its first year of growth since 2011," *The Verge*, Jan. 14, 2020, retrieved May 20, 2020, www.theverge.com/2020/1/14/21065100/pc-market-shipments-idc-gartner-growth-2019-laptops-desktops-windows-7-10.
2. O'Dea, S., "Number of smartphone unit shipments In the United States from 2013 to 2023 (In millions)," *Statista*, Feb. 27, 2020, retrieved May 20, 2020, www.statista.com/statistics/619811/smartphone-unit-shipments-in-the-us/.
3. Horowitz, Michael, "The head of NSA TAO advises on defensive computing for networks," *Computerworld*, Feb. 1, 2016, accessed May 11, 2017, www.computerworld.com/article/3028025/security/defending-a-network-from-the-nsa.html.